Università degli Studi

BlueAgent

Relatore: Pierpaolo Loreti

Correlatore: Ing. Francesco Mancini

Candidato:
Davide Luci

Anno Accademico 2023-2024

Indice

1 Introduzione **1**

2 Contesto e Confronto con lo Stato dell Arte **2**
2.1 CR Alternativi: kCTF 2
2.2 CR Alternativi: CTFBox 6
2.3 CR Alternativi: CyTrONE 8
2.3.1 Valutazione delle Performance di CyTrONE 9
2.4 CR Alternativi: CyberRangeCZ 15
2.5 CR Alternativi: CyberPatrion 18

3 BlueAgent **20**
3.1 Attori 21
3.1.1 CTF Manager (attore) 21
3.1.2 Giocatore (attore esterno per CTF Manager) 22
3.1.3 Autore della sfida (attore esterno per CTF Manager) 22
3.1.4 Amministratore della competizione (attore esterno per CTF Manager) 22
3.2 Use Cases per CTF Manager 22
3.2.1 `UC-01`: Deploy dell'infrastruttura di rete per il team k 23
3.2.2 `UC-02`: Deploy della challenge per il team k 24
3.2.3 `UC-03`: Verifica della challenge per il team k 24
3.2.4 `UC-06`: Dismissione e rilascio di una challenge per il team k . . 25
3.2.5 `UC-08`: Compilazione e Import di un'immagine per container . 26
3.2.6 `UC-12`: Registrazione e configurazione WireGuard per un membro del team k 26
3.3 Requisiti di Sistema 27
3.3.1 Piattaforma Host e Infrastruttura 27
3.3.2 Motore di Containerizzazione 27
3.3.3 Rete Ibrida e Connettivita 28
3.3.4 Motore di Verifica OVN Sandbox 28
3.3.5 Control Plane, Concorrenza e Persistenza 29
3.3.6 Pipeline Immagini Distrobuilder 29
3.4 Oracoli e Meccanismi di Verifica 29

3.4.1 Verifica Statica 30
3.4.2 Verifica Dinamica tramite sistema esterno 30
3.4.3 Verifica Dinamica tramite injection dei comandi di verifica . . 31
3.4.4 Clonazione del sistema in una rete separata 32

4 Architettura Rete Alto Livello 33
4.1 Rete production-*k* 33
4.2 Rete verify-*k* 34
4.3 Struttura di una Challenge 38

5 Architettura Nel Dettaglio e Validazione 39
5.1 Architettura del Codice 39
5.1.1 Astrazione del Runtime: `ContainerEngine` 39
5.1.2 Ciclo di Vita della Sandbox: Async Context Manager (`OVNVerifier`) 40
5.1.3 Concorrenza e Two-Tier Locking 41
5.1.4 Pipeline Asincrona non Bloccante su Socket Unix 42
5.2 Comandi per l'Architettura di Rete 42
5.2.1 Configurazione OVN e Open vSwitch 42
5.2.2 production-*k* Routing e Connettività dei Peer (WireGuard e nftables) 43
5.3 Plugin CTFd 44
5.4 Validazione 44
5.5 Difesa e Validazione di BlueAgent 46

6 Architetture Rete Alternative 48
6.1 Bridge L2 Senza Gateway 48
6.2 Interfaccia wan1 Aggiuntiva 48
6.3 Network Namespace Separato per la Verifica 49
6.4 Router Intermedio 49

7 Appendice 51
7.1 Linux Networking 51
7.1.1 Network Device Driver 51
7.1.2 Bridge 52
7.1.3 Netfilter (Capitolo 5 e 9 IPV4 routing) 53
7.2 WireGuard 54
7.3 ZFS 55
7.3.1 Vantaggi di Pool e transazioni 56
7.3.2 Quando ZFS diventa costoso? 56
7.4 NsJail e Container 56
7.4.1 Namespaces 57

7.4.2 Seccomp 57
7.4.3 cgroups 58

Elenco delle figure **59**

Elenco dei codici **59**

Elenco degli algoritmi **60**

Bibliografia **61**

Ringraziamenti **65**

Capitolo 1

Introduzione

Nel lavoro di tesi vogliamo gestire una competizione CTF (Capture The Flag).

Di solito in una competizione CTF, uno o piu' utenti (eventualmente organizzati in team) si sfidano per risolvere un'insieme di challenge, ossia recuperare una **flag**: una stringa del tipo `{hai_trovato_la_flag}`.

Ci concentreremo nel lavoro in un tipo di competizione CTF, basato sulla gestione di uno o piu sistemi vulnerabili da mitigare, dunque una competizione di Difesa dove la flag si ottiene unicamente difendendo il sistema, ossia *"patchando"* la vulnerabilita'. Nel lavoro si tiene conto del fatto che il sistema vulnerabile spesso potrebbe essere costituito da uno o piu host/nodi che comunicano tra di loro.

Le CTF hanno lo scopo di migliorare la formazione degli specialisti del settore, tramite la simulazione di scenari realistici, complessi o quantomeno molto specifici. In particolare e' fondamentale formare studenti e le risorse aziendali, per la gestione e mitigazione di sistemi vulnerabili, in modo da prevenire perdite dovute ad attacchi informatici in scenari reali. La simulazione di questi scenari avviene all'interno di un ambiente denominato Cyber Range.

Abbiamo dunque sviluppato *BlueAgent*, un'orchestratore di sistemi vulnerabili basato sulla tecnologia dei container che implementa il Cyber Range di cui abbiamo bisogno per gestire competizioni di Difesa. BlueAgent si occupa inoltre di verificare che le vulnerabilita presenti sui container siano state corrette, tramite un sistema di verifica che avviene completamente all'oscuro dei giocatori, ossia la colonazione dei container in un'ambiente separato.

INSERIRE RISULTATI OTTENUTI e METODOLOGIA USATA

Capitolo 2

Contesto e Confronto con lo Stato dell Arte

REVISION OBIETTIVO: le comparazioni non devono essere necessariamente: io faccio meglio degli altri. Ma piuttosto evidenziare cosa gli altri fanno che non faccio io, o semplicemente notare le differenze.

Secondo il NIST, un **Cyber-Range** (CR) e' definito nel seguente modo:

> "Un'ambiente interattivo, che simula la rete locale, i sistemi, i tool e le applicazioni proprietarie di un'azienda o di un'organizzazione". [1]

Ilustreremo nelle sezioni successive alcuni Cyber Range riassumendo brevemente le differenze di ognuno con BlueAgent.

2.1 CR Alternativi: kCTF

kCTF[2] e' una piattaforma sviluppata da Google, basata su *Kubernetes* e *nsjail*.

> *Kubernetes*: e' un sistema open source per automatizzare il deploy, scalare e gestire applicazioni containerizzate.[3]

> *NSJail*: ossia, NameSpace Jail, e' un tool Linux per isolare i processi utilizzando varie feature del Kernel Linux come: namespaces, resource limits, seccomp-bpf syscall filters. L'obiettivo di NSJail e' quello di creare un'ambiente sicuro e isolato per eseguire le applicazioni. [4]

Facendo riferimento all'immagine sopra, l'architettura di kCTF prevede:

[1] https://www.mdpi.com/1424-8220/20/24/7148 1. Introduction
[2] https://google.github.io/kctf/
[3] https://kubernetes.io/
[4] https://github.com/google/nsjail/

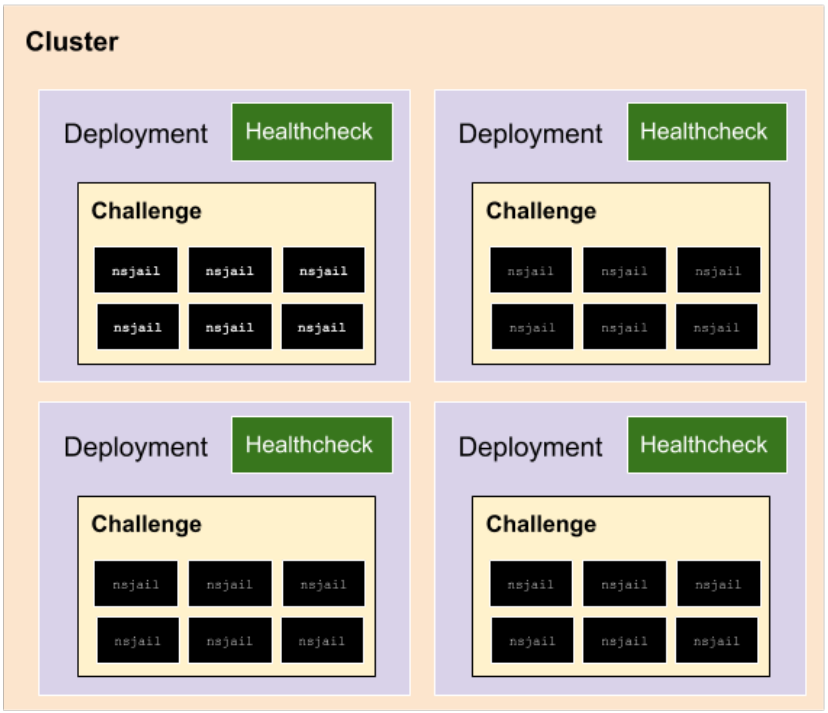


Figura 2.1: Kctf Architecture

- Un **cluster**, che contiene un'insieme di challenge
- Dei **deployment**, ognuno contiene due container (o meglio, un Pod che instanzia 2 container):
  - un container `healthcheck`: usato per determinare lo stato di salute dei servizi
  - un container `challenge`: contiene i servizi su cui lavora lo sfidante.

  Pod: in Kubernetes, e' la piu piccola unita che Kubernetes puo' eseguire. Un Pod, rappresenta uno o piu container in esecuzione su un singolo nodo.[5]

  Deployment: in Kubernetes, un deployment e' un template che specifica come creare i container. I template guidano la creazione di **Pods** e la gestione sicura del ciclo di vita di un Pod, in particolare la gestione dei ReplicaSet.[5]

NSJail viene avviato su ogni container `challenge`, ed e' configurato per ascoltare su una porta TCP nota. Ad ogni connessione TCP in arrivo, NSJail esegue un fork restituendo allo sfidante un'ambiente separato (rispetto agli altri sfidanti) su cui

[5]https://www.k8s.guide/workloads/pods-deployments/

lavorare. L'obiettivo di questa architettura e' di poter riutilizzare lo stesso container per piu sfidanti.

L'isolamento fornito da NSJail, si ottiene combinando varie tecniche:

- Creazione di nuovi namespace: l'ambiente fornito, esegue su un nuovo namespace, separando logicamente le risorse accessibili.
- Filtraggio delle chiamate di sistema tramite `seccomp-bpf`: questo sottosistema permette di uccidere i processi nell'ambiente se vengono eseguite chiamate di sistema vietate.
- Accounting e limitazione delle risorse con `cgroup`: questo sottosistema permette di monitorare e limitare le risorse utilizzabili nel nuovo ambiente.

NsJail puo' essere configurato in modo che ogni ambiente isolato, abbia a disposizione un'filesystem temporaneo che risiede in RAM, mentre il filesystem originale e' accessibile dall'ambiente sandbox in sola lettura. Questa configurazione e' necessaria poiche altrimenti gli sfidanti modificherebbero tutti lo stesso filesystem.

Un'altra configurazione di NSJail e' la seguente: che e' ideale per le challenge di tipo `pwn` (trovare e sfruttare vulnerabilita in file binari):

```
[...]
mount: [
  {
    src: "/chroot"
    dst: "/"
    is_bind: true
  },
  {
    dst: "/tmp"
    fstype: "tmpfs"
    rw: true
  },
  {
    dst: "/proc"
    fstype: "proc"
    rw: true
  },
  {
    src: "/etc/resolv.conf"
    dst: "/etc/resolv.conf"
    is_bind: true
  }
]
```

1. La cartella `/chroot` che risiede nel container, diventa la radice nel nuovo ambiente.

2. Viene creato un nuovo `tmpfs`, in `/tmp`
3. Viene importata la configurazione DNS da `/etc/resolv.conf` dentro la nuova radice.

Tutta via, l'uso di NsJail per separare gli ambienti dei partecipanti, rende difficoltosa l'implementazione di challenge in cui si vuole dare la liberta ai partecipanti di installare pacchetti dentro al container, oppure di modificare file di configurazione che risiedono per esempio in `/etc` e di modificare direttamente servizi in esecuzione sul container. [6]

Queste limitazioni ci sono perche NsJail nell'ambiente sandbox non fornisce una propria istanza di `systemd` (o un qualsiasi gestore di servizi) e neanche l'infrastruttura necessaria per eseguiure comandi come `apt`.

NsJail porta con se altri problemi:

- Se dovesse cadere la connessione TCP allora tutto il contenuto del filesytem in RAM andrebbe perso.
- L'uso di `seccomp` per filtrare le chiamate di sistema potrebbe impedire l'esecuzione di alcuni programmi fondamentali per la challenge.

Dunque kCTF potrebbe essere utilizzato per implementare un Cyber Range difensivo ma con varie limitazioni e problemi da raggirare.

L'approccio di kCTF e' completamente all'opposto di quanto fatto in BlueAgent ed in altri Cyber Range. BlueAgent si occupa di gestire piu container per ogni team, mentre kCTF assegna un container per tutti i team da dividre usando ambienti separati con NsJail.

Di seguito sono riportate le principali differenze tra kCTF ed NsJail:

Caratteristica	kCTF	BlueAgent
Virtualizzazione	Container applicativi e sandbox di processo (NSJail)	Container di sistema, ognuno con un suo gestore di servizi.
Infrastruttura	Cluster distribuito Kubernetes	Singolo nodo host
Ambiente Dedicato	Un solo container condiviso tra sfidanti	Container di sistema dedicati e separati per ciascun team
Persistenza	Filesystem effimero in RAM (`tmpfs`)	Persistente su disco

[6] https://github.com/google/kctf/blob/v1/docs/security-threat-model.md

Caratteristica	kCTF	BlueAgent
Provisioning	Istantaneo (consiste nel fork con NsJail)	Rapido (consiste nel deploy di uno o piu container)

2.2 CR Alternativi: CTFBox

CTFBox e' un Cyber Range perfetto per organizzare CTF di tipo Attack/Defense, dove ogni team ha una macchina con uno o piu servizi vulnerabili da difendere, mentre si attaccano i servizi esposti sulle macchine avversarie per recuperare le flag. Durante il gioco, ogni team deve fare attenzione a non rompere i propri servizi, mantenendo un'alta percentuale di SLA. Una SLA bassa comporta una penalita' in termini di punteggio. [7]

Fa uso di **Docker** per gestire i servizi essenziali del gioco (e che costituiscono quindi CTFBox), mentre **Incus** viene utilizzato per gestire l'esecuzione delle macchine virtuali o dei container dei team.

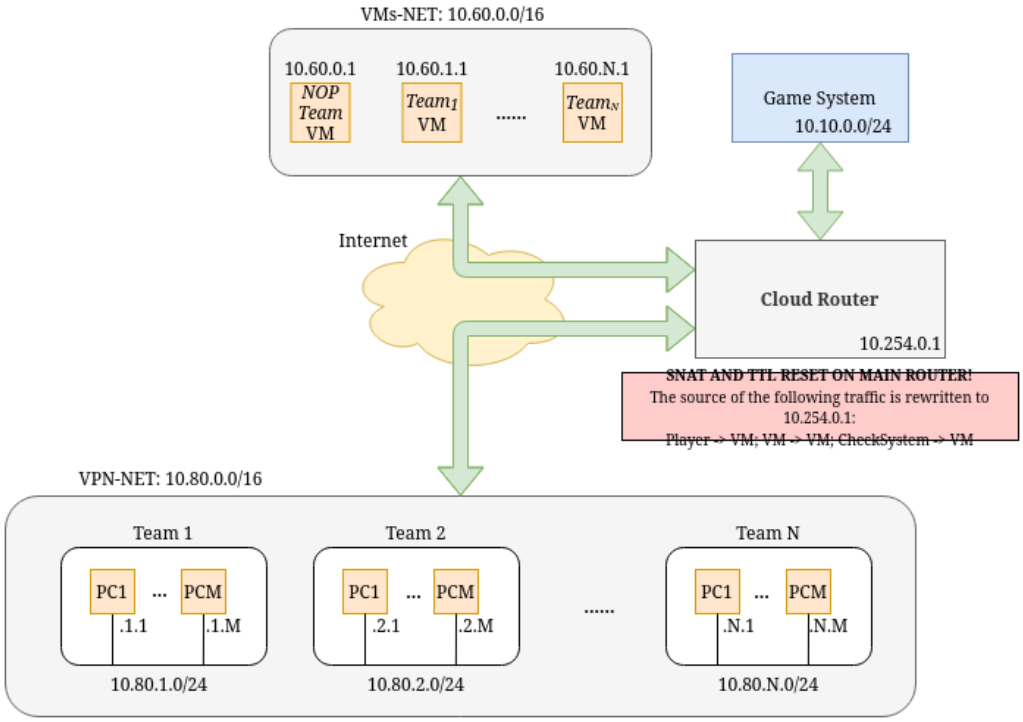


Figura 2.2: Ctfbox Architecture

Router: e' un container Docker, che gestisce le configurazioni della rete Wire-

[7] https://ctfbox.domy.sh/

Guard, permettendo ai giocatori di connettersi alla rete di gioco. Controlla le regole di routing sulla rete, e governa la transizione della rete tra 3 stati diversi:

- `freeze`: in questo stato, nessuno puo' accedere alle macchine vulnerabili
- `lock`: in questo stato, ogni team puo' accedere solo alla propria macchina vulnerabile.
- `unlock`: in questo stato, la rete e' completamente aperta, i team possono attaccare le macchine avversarie.

Game System: e' un container Docker, che agisce da cervello centrale per la gestione del gioco.

- Gestisce lo stato della rete (freeze/lock/unlock), comunicando i cambiamenti al router.
- Mantiene il database delle flag, e calcola i punteggi per ogni team.
- Coordina i Checkers, ossia i worker che interrogano i servizi dei team ad ogni tick.

In CTFBox, ad ogni tick (ossia ogni round di gioco), le flag vengono rigenerate su ogni macchina, per ogni servizio vulnerabile, e registrate nel database. L'obiettivo di un team in una competizione Attack/Defense strutturata in questo modo e' di attaccare piu volte lo stesso servizio sulle macchine avversarie, per recuperare quante piu flag possibli, finche le difese avversarie non bloccano gli attacchi.

Checkers, ad ogni tick (o round) fanno due cose:

1. Interrogano tutti i servizi vulnerabili attivi, e determinano la percentuale di SLA per ogni team.
2. Installano le nuove flag sui servizi vulnerabili.

Ogni membro del team, ha la sua configurazione **WireGuard** per conettersi alla propria macchina e per raggiungere le macchine avversarie. Ad ogni giocatore che si connette viene assegnato un'indirizzo nella sottorete `10.80.team_id.0/24` mentre le macchine dei team si trovano nella sottorete `10.60.0.0/16`.

Dunque CTFBox si rileva essere un'ottimo sistema per gestire competizioni Attack/Defense e per regolare l'accesso alle macchine, ma la sua architettura non si applica in contesti in cui vorremmo solo assegnare ad ogni team un insieme di macchine vulnerabili il cui stato verra' poi verificato da un'oracolo.

Sia CTFBox, che BlueAgent usano WireGuard ed Incus per gestire le connessioni dei partecipanti e le macchine dei vari team.

Tutta via CTFBox gestisce intere macchine virtuali mentre BlueAgent per design gestisce di default solo container di sitema.

2.3 CR Alternativi: CyTrONE

CyTrONE[8] e' un framework incentrato sul training che integra contemporaneamente sia una piattaforma educativa che un Cyber Range.

La seguente immagine mostra i componenti di CyTrONE:

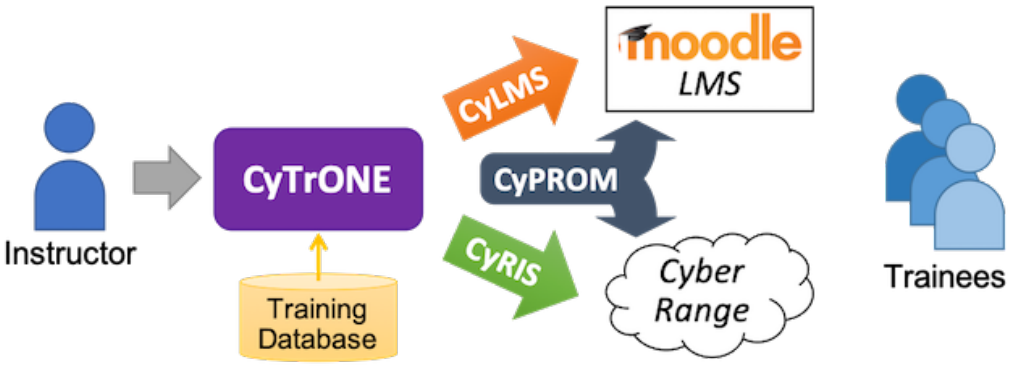


Figura 2.3: Cytrone Architecture

- **CyLMS**: si occupa d icaricare il contenuto per il training su un Learning Management System come **Moodle**
- **CyRIS** (Cyber Range Instantiation System): si occupa di istanziare l'ambiente di training su cui gli studenti possono condurre opportuni test per avanzare nel training.
- **CyPROM**: si occupa di tracciare l'avanzamento controllando LMS ed il Cyber Range.

CyTrONE gestisce tre tipi di training[9]:

- Training *Attack-oriented*: si basa sul capire come riprodurre attacchi a vulnerabilita note.
- Training *Analysis-oriented*: si concentra sull'analisi dell'attacco, per capire come funziona e le sue conseguenze.
- Training **Defense-oriented**: si conentra sulle tecniche di patching delle vulnerabilita, al fine di proteggere il sistema.

Quindi l'esperienza utente si concentra sul fatto che gli studenti possono eseguire un training e visualizzare le risorse associate sul Moodle ed al tempo stesso accedere al Cyber Range associato.

CyTrONE si applica bene facendo le seguenti assunzioni:

[8] https://github.com/crond-jaist/cytrone
[9] https://www.sciencedirect.com/science/article/pii/S0167404818306527

1) *L'obiettivo di ciascuna attività di formazione può essere formulato come un problema, che può dipendere o meno da altri problemi della stessa lezione (es: trova l'indirizzo IP, trova la flag);* [9]

2) *Il sistema è in grado di stabilire automaticamente se il partecipante abbia risolto il problema, confrontando la risposta fornita con un valore noto* [9]

L'architettura di CyTrONE e' supportata da un *Training Database*, che si occupa di tenere in memoria le informazioni per i vari training, che vengono caricate su CyTrONE da una figura identificata come *Training Coordinator*.Le informazioni mantenute nel database sono per esempio: il training content, file e programmi, macchine virtuali, ecc... [9]

CyTrONE utilizza un file YAML per definire il contenuto di un training:

E similmente, si usa un file YAML per definire la specifica del Cyber Range:

A partire dalla configurazione YAML del Cyber Range, il sotto-sistema CyRIS si occupa di istanziarlo. Successivamente, in caso di un training **Defense-oriented** l'utente richiede l'attacco associato alla vulnearbilita all'interno del sistema e ne viene registrato l'esisto.

Tutta via, sebbene il sistema sia ben ingegnerizzato soffre di alcuni problemi:

1. Il deploy delle vulnerabilita avviene su macchine virtuali, che possono costituire un alto overhead in termini di risorse, ed tempi di approvvigionamento lunghi per l'infrastruttura.
2. Il payload viene inviato remotamente dal `cyberattack controller` (che non fa altro che eseguire `Metasploit`). Tutta via il traffico di rete puo' essere intercettato dallo studente, ottenendo cosi suggerimenti per la soluzione.
3. L'esecuzione del payload puo scatenare la produzione di file log accessibili allo studente.
4. L'esecuzione del payload potrebbe mandare in crash il sistema del partecipante.
5. Necessita di un LMS (per design) per tenere traccia del training progress.

2.3.1 Valutazione delle Performance di CyTrONE

Le performance di CyTrONE per il deploy dell'infrastruttura sono state valutate usando il testbed StarBED [10], usando 30 host fisici e 600 macchine virtuali. Gli host fisici usati per misurare le performance sono dei *server rack Cisco UCS C200 M2 con Intel Xeon E5504 2.0 GHz a 4 core e 72 GB di memoria*

Sono stati valutati 2 scenari:

[10]https://www.sciencedirect.com/science/article/pii/S0167404818306527#bib0015

```
---
- training:
  - id: L1-EN
    title: |
      Investigate the security of a desktop
      computer
    overview: |
      Today is your first day on the job as
      a sysadmin. Your boss tells you that he
      suspects somebody tried to hack into
      your company's network, and asks you to
      investigate a possible cyber attack
      that may have happened when the system
      administrator was a guy called Daniel
      Craig. The boss sits you in front of
      the previous sysadmin's computer, and
      wishes you good luck.

      You glance at the machine and
      reluctantly get to work.
    level: 1

    questions:
    - id: L1-EN-001
      body: |
        The operating system and kernel
        release number can tell you about
        the possible vulnerabilities of a
        computer. Find out the full kernel
        release number of the machine (e.g.,
        3.4.5-6.7.8.abc.x86_64).
      answer: 3.10.0-514.21.1.el7.x86_64
      hints:
      - You can use the command uname to
        find out OS details.
      - $ uname -r
      - An alternative solution is to check
        the /proc/version file.
```

Figura 2.4: Cytrone Training

```
---
- host_settings:
  - id: host_1
    mgmt_addr: {{ host_mgmt_addr }}
    virbr_addr: {{ host_virbr_addr }}
    account: {{ host_account }}

- guest_settings:
  - id: desktop
    basevm_host: host_1
    basevm_config_file: /imgs/basevm_desktop.xml
    basevm_type: kvm
    basevm_name: basevm_desktop
    tasks:
    - add_account:
      - account: daniel
        passwd: daniel_passwd
        full_name: Daniel Craig
    - install_package:
      - package_manager: yum
        name: wireshark
    - emulate_attack:
      - attack_type: ssh_attack
        target_account: daniel
        attempt_number: 123
        attack_time: 20170123
    - emulate_malware:
      - name: DAEMON
        cpu_utilization: 40
        mode: dummy_calculation

- clone_settings:
  - range_id: {{ clone_range_id }}
    hosts:
    - host_id: host_1
      instance_number: {{ clone_instance_number }}
      guests:
      - guest_id: desktop
        number 1
        entry_point: yes
      topology:
      - type: custom
        networks:
        - name: office
          members: desktop.eth0
```

Figura 2.5: Cytrone Cyberrange

- *Level 1*: un training base che include tra gli argomenti: log, configurazioni di sistema, sniffing della rete e scansione delle vulnerabilita. Richiede un'unica macchina Virtuale per fare il deploy dello scenario
- *Level 2*: un training di difficolta media su topic come il network discovery, penetration testing e password cracking. Richiede due macchine virtuali per il deploy dello scenario.

Il processo di deploy del training, per una sola macchina virtuale, in CyTrONE avviene in 3 fasi distinte:

1. **Preparazione**: Su un nodo denominato *master* viene configurata (per esempio, accesso tramite SSH) ed avviata la macchina virtuale. T_p descrive il suo tempo di esecuzione
2. **Installazione**: Sulla macchina nel nodo master, vengono installati contenuti aggiuntivi necessari per il traninig, sulla macchina virtuale target. T_i descrive il suo tempo di esecuzione.
3. **Clonazione**: Copia tramite `parallel-scp` dell'immagine della macchina sui vari nodi della rete, garantendo al tempo stesso che password e credenziali siano distinte per ogni immagine. T_c descrive il suo tempo di esecuzione

   E' dunque importante notare che per il *Level 1*, bisogna clonare con `parallel-scp` una sola immagine per nodo, mentre per il *Level 2* bisogna clonare 2 immagini per nodo.

Sia $T = T_p + T_i + T_c$, il grafico descrive come si comporta T al variare del numero di host su cui fare il deploy delle macchine.

- Nei casi dove abbiamo solo 1 host, allora non c'e' bisogno di clonare l'immagine, basta solo un host che esegue le 20 macchine virtuali, ossia il master. Dunque il tempo di clonazione e' sotto i *due minuti*, mentre T per lo scenario *Level 2* si attesta sotto gli 8 minuti.
- All'aumentare del numero n degli host, con il bisogno di clonare le macchine su piu nodi, il tempo di approvvigionamento totale tende a peggiorare, poiche bisogna trasferire l'immagine su piu nodi, sebbene ogni nodo gestisca solo $20/n$ macchine virtuali.

Invece, per gli esperimenti su larga scala dove si vuole effettuare il deploy di 20 macchine per ogni host su centinaia di host il tempo T peggiora esponenzialmente. Nella figura sborgz viene analizzato al variare di del numero di host fino a 600 cosa succede se ogni nodo deve eseguire 20 macchine, con 20 immagini differenti.

Le differenze tra CyTrONE e Blueagent sono elencate nella seguente tabella:

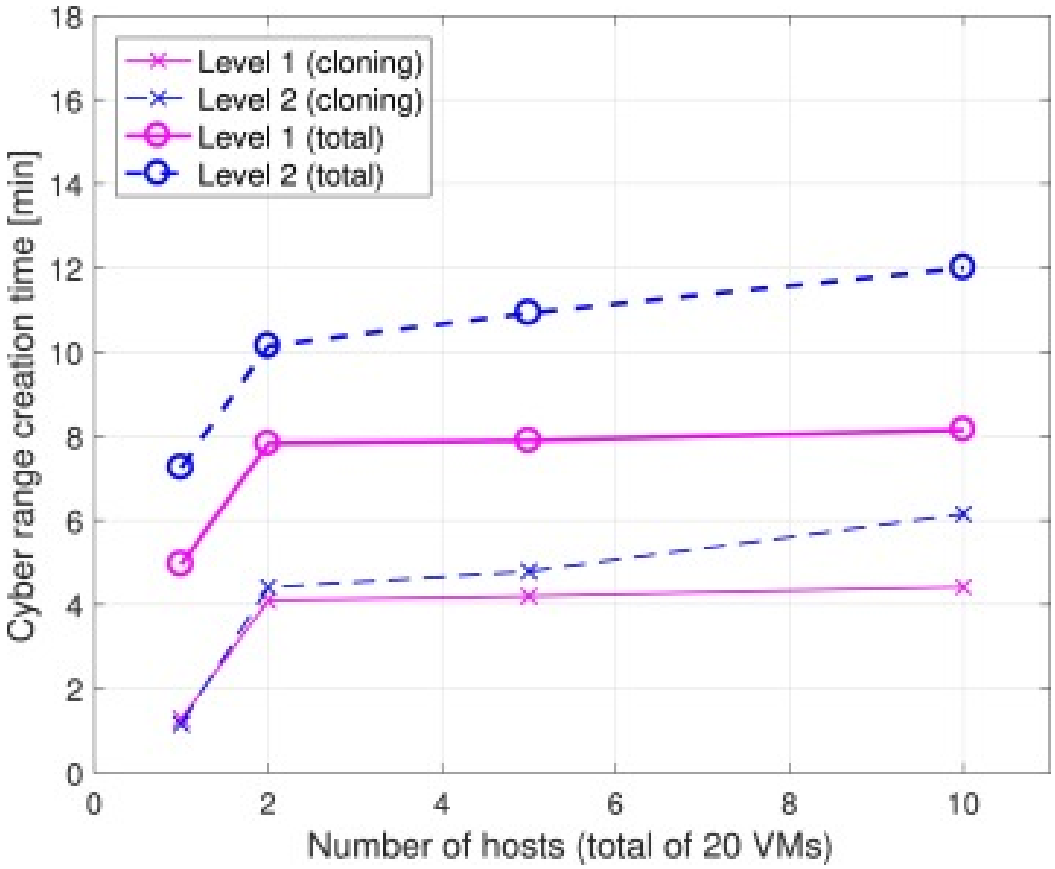


Figura 2.6: Cytrone Performance

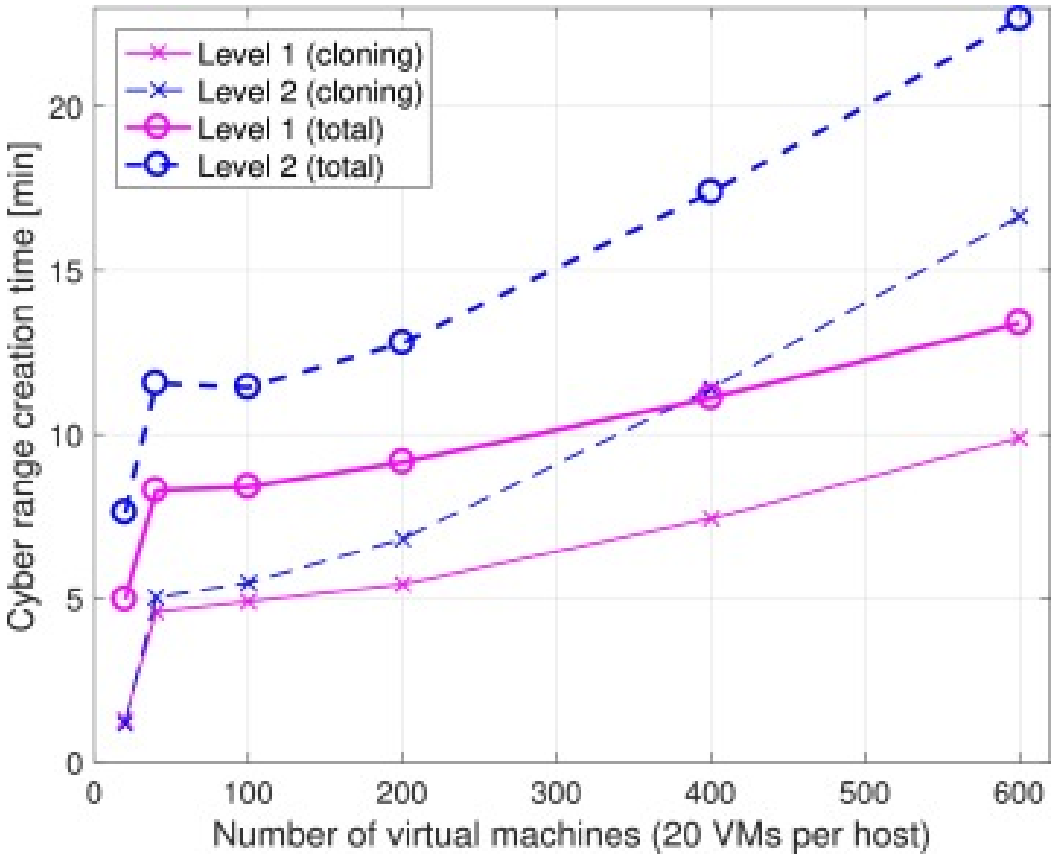


Figura 2.7: Cytrone Largescaleperformance

Caratteristica	CyTrONE	BlueAgent
Virtualizzazione	Macchine Virtuali	Container di sistema
Infrastruttura	Cluster distribuito su larga scala (es: *StarBED*)	Singolo nodo host
Isolamento e Verifica	Il controller invia exploit via rete	Exploit inviati in una rete separata inaccessibile al giocatore
Rete	Reti virtuali KVM	Linux Bridge per L2, SDN, WireGuard per L3
Scopo Principale	Formazione didattica guidata con Moodle e verifiche statiche sulle macchine	Cyber Range compatto per competizioni di Difesa

2.4 CR Alternativi: CyberRangeCZ

CyberRangeCZ e' un fork di **KYPO**. E' una piattaforma basata su OpenStack per fornire un'ambiente cloud su cui fare il deploy delle macchine. Utilizza tecnologie moderne come container, IaC (infrastructure as code) ed i microservizi.

Macchine virtuali, reti, e training sono definiti utilizzando JSON e YAML. Questi file vengono passati ad Ansible per descrivere il contenuti della macchina e ad Packer per costruire le immagini delle macchine virtuali.

Fa uso massivo della virtualizzazione per ricreare fedelmente reti complesse ed interi sistmi operativi.

La piattaforma si concentra per soddisfare due casi d'uso principali:

- emulare intere infrastrutture di computer in ambienti controllati
- eseguire più sessioni di training contemporaneamente, gestendo centinaia di ambienti virtuali per centinaia o migliaia di partecipanti.

La piattaforma CyberRangeCZ si occupa di creare e approvvigionare un'ambiente virtuale emulato costituito da Sandbox e Pool.

> **Sandbox**: *"È un ambiente di test isolato con reti virtuali che consente agli utenti di connettersi alle macchine virtuali (VM) e comunicare con il resto della rete, la macchina host e le altre VM. Sulle VM, l'utente può eseguire programmi, utilizzare servizi di rete o monitorare il traffico di*

rete, il tutto senza influire sull'infrastruttura esterna. La sandbox viene eseguita all'interno del cloud ed è accessibile da remoto." [11]

Pool: *"Un gruppo di sandbox cloud create a partire dalla medesima sandbox definition."* [11]

All'interno di una sandbox e' possibile fornire una **Topology Definition**, un file che decsrive la struttura dell'ambiente (host, router, reti, etc.) mentre il **Sandbox Provisioning** si occupa di customizzare le instanze nella topologia.

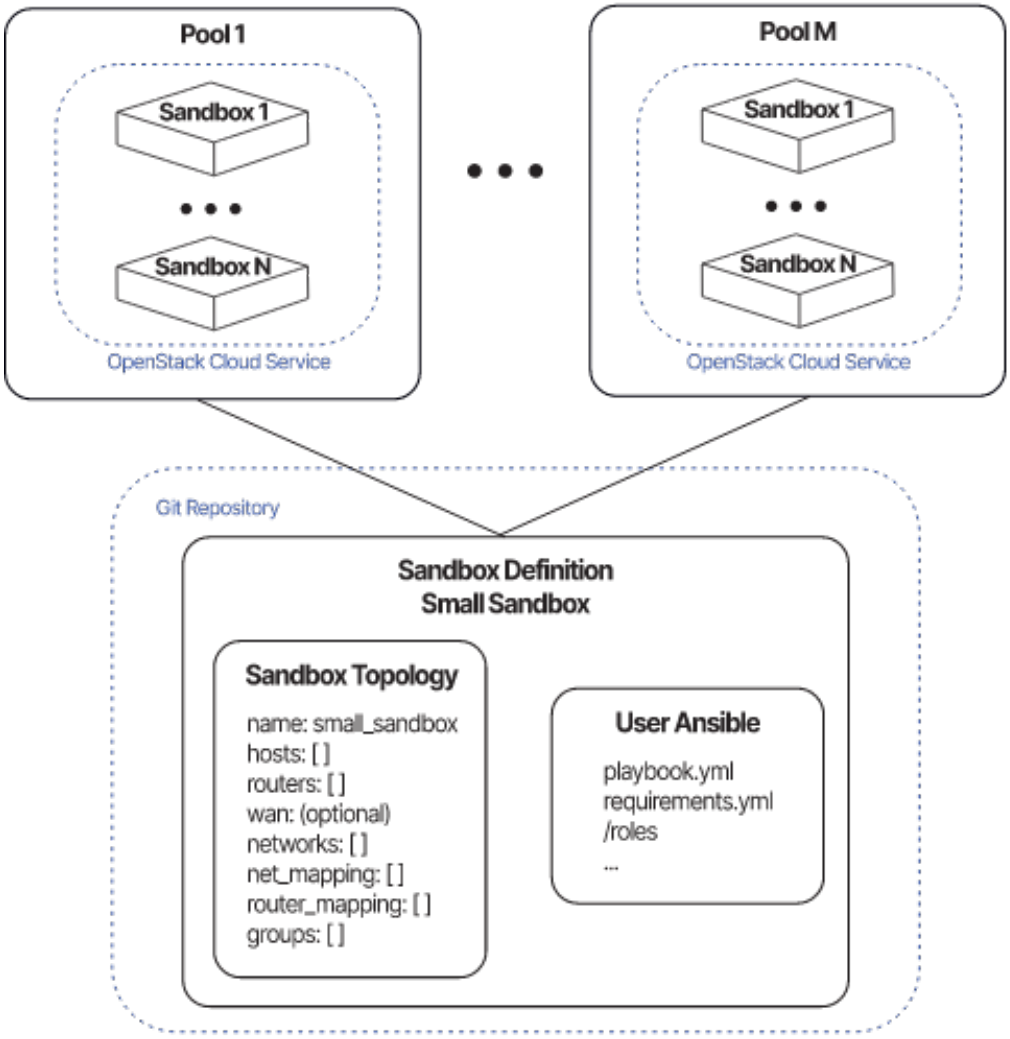


Figura 2.8: Kypo Basic Elements Sandboxes

La creazione di una Sandbox si divide in 3 fasi:

- **Allocazione**: creazione della sandbox (=macchine virtuali) dentro al cloud.

[11] https://docs.platform.cyberrange.cz/basic-concepts/terminology/#emulated-virtual-environment

- **Networking**: setup della rete e distirbuzione delle chiavi di accesso dentro le macchine.
- **Provisioning**: customizzazione delle macchine virtuali nella sandbox.

  La creazione della Pool precede necessariamente la creazione delle Sandbox.

A partire dalla Topology Definition, viene prodotta la **Topology Instance** utilizzando `Terraform` (che crea l'infrastruttura virtuale). L'accesso alla topologia e' regolato da un MAN (Management Access Node), ossia l'unico nodo connesso all'esterno della rete della Topology Instance.

Di seguito, nell'immagine sburgoz, viene mostrata l'architettura generale di una Topology Instance.

L'accesso alle macchine dentro la Sandbox e' regolato tramite SSH, oppure da una console web accessibile via browser.

Gestire Sandobx, ossia intere Topology Instance e' costoso, infatti i requisiti sono i seguenti:

- una macchina virtuale con almeno *2 core CPU, 16 GB di RAM e 40 GB di archiviazione*
- un server dotato di almeno *16 core CPU, 128 GB di RAM, 2 TB di archiviazione e almeno due interfacce di rete.*

Requisiti cosi alti sono necessari per:

- gestire l'infrastruttura OpenStack, i microservizzi, e Kubernetes
- gestire l'esecuzione di centinaia di macchine virtuali e garantire la scalabilita al crescere degli utenti.

CyberRangeCZ a differenza di BlueAgent gestisce un'intera rete cloud, su cui vengono orchestrati container, configurati dinamicamente con Ansible e gestiti via Kubernetes, mentre BlueAgent e' un orchestratore di container che esegue su un'unico host.

Di seguito sono illustrate le principali differenze tra CyberRangeCZ e BlueAgent:

Caratteristica	CyberRangeCZ	BlueAgent
Virtualizzazione	Macchine Virtuali (VM)	Container di sistema (Incus)
Infrastruttura	Cluster Cloud distribuito (OpenStack, Kubernetes)	Singolo nodo host (Debian 13)

Caratteristica	CyberRangeCZ	BlueAgent
Requisiti Hardware	Elevati (16+ core, 128+ GB RAM, 2 TB disco)	Minimi (eseguibile su singolo server o PC economico)
Configurazione	Runtime con Ansible e template Packer	Creazione immagine con Distrobuilder
Provisioning	Lento (nell'ordine dei minuti)	Rapido (nell'ordine dei secondi con CoW)
Rete	Rete virtuale OpenStack con nodo MAN	Linux Bridge L2, WireGuard VPN e SDN OVN
Verifica Difesa	Non prevista nativamente	Cloni ZFS CoW su switch OVN isolato
Scopo Principale	Emulazione reti aziendali e training su larga scala	Cyber Range compatto per CTF di difesa

2.5 CR Alternativi: CyberPatrion

E' un programma di educazione nazionale per il K-12 creato dalla *Air & Space Forces Association*. I team assumono giocano il ruolo di professionisti di cybersecuirity che hanno l'obiettivo di proteggere vari sistemi entro un limite di tempo, analizzando le macchine virtuali, identificandone le vulnerabilita e mitigandole.

Il CyberPatriot Scoring System (CSS) tiene traccia della progressione del team. Un demone locale esegue controlli periodici sulla macchina per determinarne lo stato, mentre un server centrale registra i punteggi comunicando con i demoni delle macchine.

Questo sistema tutta via e' **closed-source** e solo l'**AFA** puo' utilizzarlo.

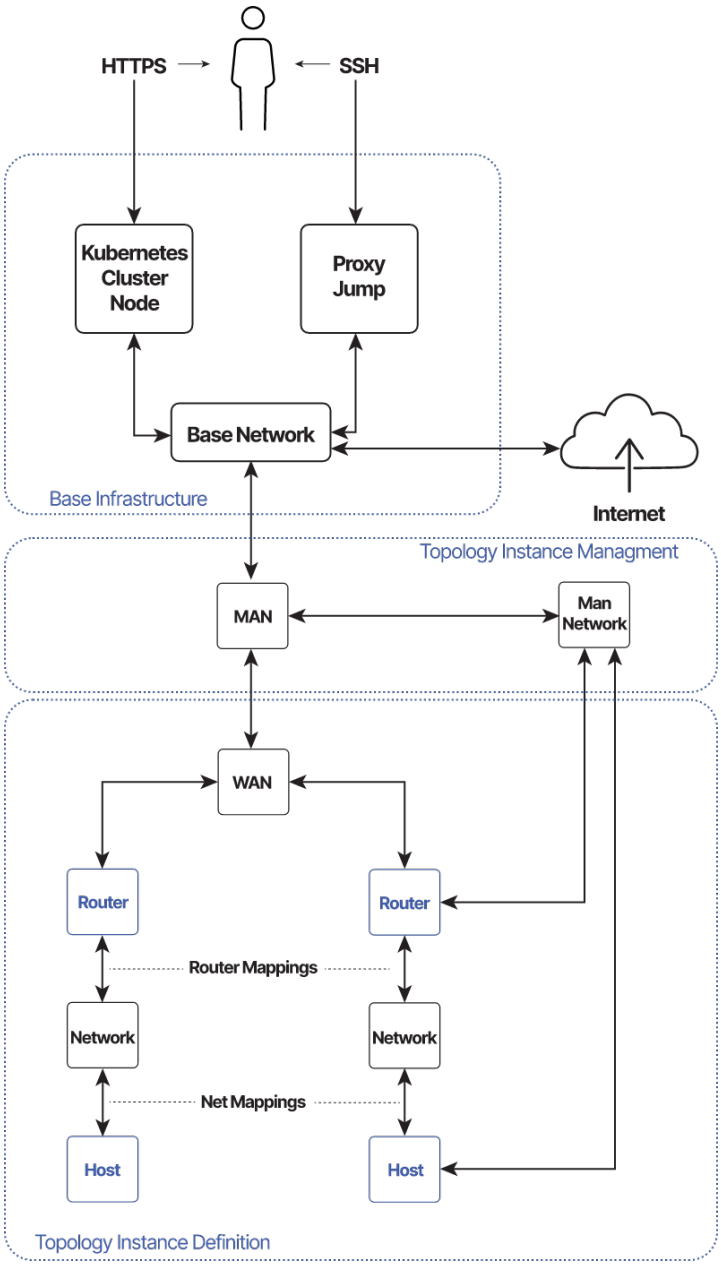


Figura 2.9: Kypo Topology Instance

Capitolo 3

BlueAgent

Si vuole presentare dunque il nostro Cyber Range: *BlueAgent*. Un servizio *HTTP* che implementa delle *API REST* per la gestione e la verifica delle macchine a partire da file dichiarativi (*IaC*) fornite dagli organizzatori della CTF. Queste API REST potranno poi essere sfruttate ed implementate da un qualsiasi applicativo (denominato CTF Manager) per gestire le challenge, come per esempio, un plugin per CTFd[1].

Il Cyber Range implementato da BlueAgent e' pensato per scenari di Patch Management da eseguire su un unico nodo con hardware "leggero". Dunque si vuole offrire un'ambiente basato su container (invece di utilizzare delle macchine virtuali pesanti) che offra un meccanismo di verifica completamente nascosto ai giocatori. Tale meccanismo e' basato sulla clonazione sul momento dell'intera infrastruttura interessata, in una rete separata e inaccessibile ai giocatori, su cui verranno poi eseguiti i comandi dell'oracolo definito in fase di dichiarazione.

I membri dei team, potranno connettersi alla rete dei container a loro assegnati utilizzando una VPN, implementata da WireGuard, tenendo presente che ogni membro avra' un peer associato (una coppia di chiavi pubbliche e private).

E' importante puntualizzare che:

1. Gli indirizzi IP dei container, nelle reti dei giocatori, saranno statici e noti a priori (questo scenario si applica alla stragrande maggioranza delle challenge)
2. Il meccanismo di duplicazione avviene sfruttando il meccanismo CoW di ZFS per abbattere il costo in memoria. Inoltre utilizzeremo una SDN per semplificare la gestione e la creazione di router e switch necessari ai container duplicati.
3. BlueAgent non mantiene in memoria lo stato delle challenge (per esempio i punteggi dei vari team). Questo software deve essere inteso come un'orchestratore di container. Blueagent si limita a prendere in input la definzione di una challenge e di istanziare i container richiesti.

[1] https://ctfd.io/

A scopo d'esempio mostriamo come creare ed istanziare una challenge con BlueAgent:

1. Il creatore della challenge definisce in modo dichiarativo i container.
2. Il creatore della challenge, inserisce nel CTF Manager la nuova challenge tenendo in memoria tutte le informazioni necessarie a BlueAgent (inclusi i file dichiarativi)
3. Il giocatore di un determinato team, accede alla challenge e tramite il CTF Manager richiede la creazione dei container
4. Il CTF Manager invia a BlueAgent i file di configurazione della challenge da istanziare
5. BlueAgent si occupa di istanziare i container per il team.

BlueAgent e' basato su *FastAPI*, per gestire in modo semplice ed efficiente le richieste HTTP.

L'host su cui viene eseguito BlueAgent deve mettere a disposizione dell'architettura le seguenti componenti:

- **Debian 13**: o un qualsiasi distribuzione Linux.
- `nftables`: per filtrare i pacchetti nel Kernel
- **Python 3**: per eseguire BlueAgent.
- **Pool ZFS**: filesystem che supporta il meccanismo `COW`.
- **OVN ed Open vSwitch**: per gestire la rete di verifica dei container.
- **Distrobuilder**: per generare le immagini dei container in modo dichiarativo.
- **WireGuard**: per fornire una VPN come punto d'accesso ai partecipanti
- **Incus**: per la gestione dei container.

Per comprendere passo-passo cosa permette di fare il sistema e come lo fa sono elencati gli attori, gli use cases ed i requisiti di sistema.

3.1 Attori

L'attore e' un'entita logica esterna al sistema che interagisce direttamente con esso, tramite l'invio di messaggi. E' utile identificare ai fini dell'esposizione quali sono gli attori principali del sistema e che cosa si aspettano di poter fare.

3.1.1 CTF Manager (attore)

E' un sistema software esterno a BlueAgent che si occupa di gestire la competizione (punteggi, team, utenti, configurazioni, gara). Comunica con BlueAgent tramite API REST per gestire l'intero ciclo di vita delle macchine dei team, ed agisce come entita autenticata (tramite l'utilizzo di un token) per BlueAgent. Mantiene lo stato delle challenge, siccome BlueAgent, per design non lo fa.

Richiede per conto dei Giocatori il deploy delle challenge, la verifica dei container e le configurazioni per accedere alla rete tramite VPN.

Per conto dell'autore della sfida permette la gestione dei file di configurazione delle challenge. Permette invece all'admin di gestire i container attivi, i team, e altri aspetti della gara.

Piu avanti, verra presentato un plugin per CTFd, che agisce come CTF Manager verso BlueAgent.

Dunque CTF Manager e' l'unico attore per BlueAgent e rendere il CTF Manager esterno ed indipendente da BlueAgent nella sua architettura, permette di non vincolare l'uso di BlueAgent con CTFd.

Ora vogliamo definire meglio il ruolo che hanno l'Admin, il Giocatore e l'Autore della sfida (o challenge). Chiariremo subito che questi tre non sono attori che dialogano direttamente con BlueAgent.

3.1.2 Giocatore (attore esterno per CTF Manager)

E' un'entita che agisce in team con altri giocatori, oppure da solo. Ha accesso alle macchine delle challenge istanziate da BlueAgent, appartenenti al suo team. Non comunica direttamente con BlueAgent ma piuttosto si interfaccia con il CTF Manager per gestire la progressione nella competizione e per richiedere il deploy delle macchine.

3.1.3 Autore della sfida (attore esterno per CTF Manager)

Si occupa di creare i file di configurazione per una o piu challenge e di inviare tramite CTF Manager le immagini dei container definite tramite configurazione distrobuilder. Dunque non dialoga direttamente con BlueAgent

3.1.4 Amministratore della competizione (attore esterno per CTF Manager)

Per aspetti legati alla gestione della competizione CTF si interfaccia direttamente con il CTF Manager. Se ha bisogno di interagire con configurazioni di team e container, il CTF Manager cattura le richieste dell'amministratore (tramite interfaccia apposita di amministrazione) e le inoltra a BlueAgent.

3.2 Use Cases per CTF Manager

Sono elencati di seguito gli Use Case per il CTF Manager, arricchito con alcuni dettagli implementativi per comprendere al meglio l'architettura del software.

Di seguito e' riportato un breve glossario:

`br-team-k`: e' il bridge di rete che fornisce una rete locale per i container del team k. Ogni `br-team-k` e' logicamente separato dagli altri `br-team-k`.

`wg-k`: e' l'interfaccia WireGuard che offre la connettivita VPN per il team k verso `br-team-k`.

`eth0`: in questo documento, spesso identifica il nome dell'interfaccia che fornisce la connettivita alla LAN per un container.

`verify-k`: e' lo switch logico (gestito tramite OVN SDN) utilizzato per implementare la rete di verifica per il team `k`. Questa rete e' completamente scollegata da `br-team-k` e da `wg-k`.

`database`: e' il database SQL, usato da BlueAgent per tenere traccia delle risorse allocate.

3.2.1 `UC-01`: Deploy dell'infrastruttura di rete per il team k

- **Attore**: CTF Manager
- **Obiettivo**: Effettuare il deploy delle interfacce di rete necessarie al team k per eseguire i container e consentire l'accesso VPN ai partecipanti.
- **Precondizione**: BlueAgent e' attivo ed e' raggiungibile via API REST.

Flusso delle azioni:

1. Il CTF Manager invia la richiesta `PUT /teams/{team_k}`, specificando l'identificativo k nel path ed il relativo nome nel payload.
2. BlueAgent verifica se l'infrastruttura per il team k esiste gia:
    1. Se il team e' gia registrato, ne sincronizza la configurazione e risponde `HTTP 200 OK`.
    2. Altrimenti, l'infrastruttura di rete viene creata da zero:
        1. Viene creato il bridge `br-team-k` per il team k con IP per il gateway `10.k.1.1/24`.
        2. Viene creata l'interfaccia WireGuard `wg-k` per il team k. La porta UDP e' `51820+k`, l'IP per il gateway e' `10.k.0.1/24`.
        3. Viene registrato il team all'interno del database.
        4. BlueAgent risponde con stato `HTTP 201 Created` confermando l'avvenuta creazione.

Se avviene un errore irrimediabile durante la creazione, il bridge e l'interfaccia WireGuard create vengono rilasciate.

3.2.2 `UC-02`: Deploy della challenge per il team k

- **Attore**: CTF Manager
- **Obiettivo**: Effettuare il deploy dei container necessari alla challenge da allestire per il team k richiedente.
- **Precondizione**: `UC-01`, `UC-08`. E' stato eseguito con successo il deploy dell'infrastruttura di rete per il team k e le immagini dei container richieste sono presenti nel catalogo in stato `ready`.

Flusso delle azioni:

1. Il CTF Manager invia la richiesta `POST /teams/{team_k}/machines` specificando la configurazione della challenge.
2. BlueAgent valida le precondizioni.
3. Per ogni container specificato nella configurazione:
    1. Crea l'istanza del container.
    2. Collega l'interfaccia virtuale `eth0` dell'istanza al bridge del team `br-team-k`.
    3. Inietta nel filesystem dell'istanza la configurazione di rete statica.
    4. Avvia l'istanza del container ed applica l'indirizzo IP statico.
    5. Registra il container nel database.
4. BlueAgent restituisce la risposta con stato `HTTP 201 Created`.

Se si verifica un errore durante l'avvio, BlueAgent arresta ed elimina tutte le istanze e le risorse create fino a quel momento per la challenge e risponde con un errore.

3.2.3 `UC-03`: Verifica della challenge per il team k

- **Attore**: CTF Manager
- **Obiettivo**: Verificare l'integrita dei servizi e l'efficacia delle patch applicate dal team mediante l'esecuzione dei comandi specificati nella configurazione della challenge.
- **Precondizioni**: `UC-02`. I container relativi alla challenge specificata per il team k sono attivi.

Flusso delle azioni:

1. Il CTF Manager invia la richiesta `POST /teams/{team_k}/verificator` trasmettendo la configurazione della challenge da verificare.
2. Se una verifica per lo stesso team e' gia in corso, BlueAgent risponde con `HTTP 409 Conflict`.
3. Altrimenti, BlueAgent predispone l'ambiente di verifica:

1. Crea uno switch logico OVN denominato `verify-k`.
2. Esegue la clonazione CoW (ZFS) di tutti i container della challenge del team k.
3. Riconfigura l'interfaccia `eth0` dei cloni agganciandola allo switch OVN di verifica.
4. Avvia i cloni sandbox e configura al loro interno lo stesso indirizzo IP statico di produzione `10.k.1.{ip_suffix}/24`.
5. Se specificato nella configurazione, avvia un container di verifica runner.

4. Esecuzione dei controlli di readiness: viene eseguito un ciclo di tentativi finche' il comando non ha successo, oppure fino allo scadere del timeout.
5. Esegue i comandi di verifica all'interno dei container clonati o dal container runner.
6. Dealloca in ordine inverso (LIFO) le risorse sandbox create per il controllo.
7. BlueAgent risponde con stato `HTTP 200 OK` comunicando l'esito della verifica.

Se si verifica un errore, oppure i comandi di readiness non hanno successo, allora le risorse utilizzate vengono rilasciate e viene comunicato l'errore.

3.2.4 `UC-06`: Dismissione e rilascio di una challenge per il team k

- **Attore**: CTF Manager
- **Obiettivo**: Rimuovere tutti i container associati a una determinata challenge per il team k.
- **Precondizioni**: I container associati alla challenge specificata sono attivi per il team k.

Flusso delle azioni:

1. Il CTF Manager invia la richiesta `DELETE /teams/{team_k}/machines` specificando nel payload la configurazione della challenge.
2. Per ciascun container specificato nella configurazione della challenge:
    1. Arresta l'istanza.
    2. Elimina l'istanza.
    3. Cancella il record del container dal database.
3. BlueAgent risponde con stato `HTTP 204 No Content`.

In caso di problemi durante il teardown di uno o piu container, BlueAgent restituisce un errore HTTP con i dettagli dell'anomalia.

3.2.5 `UC-08`: Compilazione e Import di un'immagine per container

- **Attore**: CTF Manager
- **Obiettivo**: Inviare la specifica di un'immagine in formato YAML ed avviare la compilazione e l'importazione nel catalogo delle immagini.
- **Precondizione**: BlueAgent e' attivo.

Flusso delle azioni:

1. Il CTF Manager invia la richiesta `PUT /images/{alias}` inviando una form multipart con il file di definizione YAML o l'archivio di contesto.
2. BlueAgent valida la specifica YAML e ne calcola l'hash crittografico.
3. BlueAgent verifica lo stato dell'immagine nel database:
    1. Se l'immagine con lo stesso hash esiste gia ed e' in stato `ready`, risponde immediatamente con `HTTP 200 OK`.
    2. Altrimenti, registra un nuovo record nel database in stato `building`.
4. BlueAgent avvia la compilazione tramite un worker asincrono:
    1. Esegue Distrobuilder ed importa l'immagine generata nel catalogo dei container Incus.
    2. Assegna l'alias all'immagine importata e aggiorna il record a `ready` nel database.
5. BlueAgent restituisce immediatamente al CTF Manager lo stato `HTTP 202 Accepted` se la compilazione e' stata avviata.

3.2.6 `UC-12`: Registrazione e configurazione WireGuard per un membro del team k

- **Attore**: CTF Manager
- **Obiettivo**: Registrare un giocatore come membro del team k, allocare un indirizzo IP nella subnet VPN, generare le chiavi crittografiche WireGuard e restituire il file di configurazione `.conf`.
- **Precondizioni**: `UC-01`. L'infrastruttura di rete per il team k e' attiva sul sistema.

Flusso delle azioni:

1. Il CTF Manager invia la richiesta `PUT /teams/{team_k}/members/{user_id}` fornendo il nome dell'utente ed opzionalmente la chiave pubblica WireGuard.

2. BlueAgent verifica se il team k e' registrato; se assente, risponde con `HTTP 404 Not Found`.
3. BlueAgent verifica se il membro e' gia registrato nel database per il team k:
    1. Se il membro esiste gia, BlueAgent aggiorna la configurazione rispondendo con `HTTP 200 OK`.
    2. Se il membro e' nuovo:
        1. Alloca un indirizzo IP VPN libero per il team (`10.k.0.2 - 10.k.0.254`). Se lo spazio degli indirizzi e' esaurito, risponde con `HTTP 409 Conflict`.
        2. Se non fornita, genera una nuova coppia di chiavi asimmetriche.
        3. Registra il nuovo peer sull'interfaccia `wg-k`.
        4. Salva il record del membro nel database.
4. BlueAgent risponde con stato `HTTP 201 Created` restituendo i dati del membro e la configurazione WireGuard generata.

3.3 Requisiti di Sistema

I requisiti di sistema definiscono i vincoli architetturali, infrastrutturali e operativi che BlueAgent deve garantire per supportare i casi d'uso descritti.

3.3.1 Piattaforma Host e Infrastruttura

- **`SR-HST-01` (Sistema Operativo Host)**: L'host deve eseguire Debian 13 (e quindi un Kernel Linux), con IP forwarding abilitato e fornire `nftables`.
- **`SR-HST-02` (ZFS)**: L'host deve disporre di uno storage pool ZFS con supporto nativo a snapshot.
- **`SR-HST-03` (SDN)**: L'host deve eseguire i servizi Open vSwitch e OVN (`ovs-vswitchd`, `ovn-northd`, `ovn-controller`) per il provisioning degli switch logici necessari all'implementazione della rete di verifica.
- **`SR-HST-04` (Supporto WireGuard)**: L'host deve disporre di WireGuard per la gestione dei tunnel VPN.
- **`SR-HST-05` (Distrobuilder)**: L'host deve disporre del compilatore `distrobuilder` per la generazione delle immagini dei container vulnerabili.

3.3.2 Motore di Containerizzazione

- **`SR-ENG-01` (Astrazione)**: Disaccoppiamento della logica di orchestrazione tramite interfaccia astratta `ContainerEngine` per garantire l'indipendenza del codice da Incus.
- **`SR-ENG-02` (Client Asincrono)**: Comunicazione non bloccante con Incus via Unix Domain Socket mediante client HTTP asincrono.

- `SR-ENG-03` **(Limitazione Risorse)**: Applicazione di quote hardware per container (`limits.cpu` e `limits.memory`) per impedire starvation delle risorse.
- `SR-ENG-04` **(Clonazione Snapshot CoW)**: Duplicazione istantanea delle istanze dei container basata su snapshot CoW a livello di storage.

3.3.3 Rete Ibrida e Connettivita

- `SR-NET-01` **(Terminazione Gateway VPN)**: Ogni team ha a disposizione l'interfaccia WireGuard `wg-k` su porta UDP $51820 + k$ ed IP gateway `10.k.0.1/24`.
- `SR-NET-02` **(Linux Bridge L2)**: Ogni team ha a disposizione un bridge L2 `br-team-k`, con gateway `10.k.1.1/24` per garantire prestazioni di inoltro alla velocita della RAM e che funzioni da punto d'aggancio per i container del team.
- `SR-NET-03` **(Indirizzamento e Credenziali VPN)**: Allocazione degli indirizzi IP per i membri del team nella subnet `10.k.0.0/24` e generazione delle chiavi asimmetriche.
- `SR-NET-04` **(Topologia Deterministica)**: Configurazione statica della rete nei container in base al suffisso per l'indirizzo IP fornito nella configurazione della challenge.
- `SR-NET-05` **(TCP MSS Clamping)**: Applicazione di regole `nftables` per forzare il clamping del MSS, prevenendo blackhole dovuti alla riduzione di MTU causata dal tunnel WireGuard.
- `SR-NET-06` **(Isolamento e Masquerading NAT)**: Isolamento del traffico tra team differenti via `@team_links` e masquerading del traffico uscente verso Internet.

3.3.4 Motore di Verifica OVN Sandbox

- `SR-VRF-01` **(Switch OVN)**: Creazione di una rete OVN in fase di verifica, isolata e senza esporre il gateway dello switch all'host per prevenire sovrapposizione di rotte.
- `SR-VRF-02` **(Fedelta Topologica)**: I cloni nell'ambiente di verifica preservano l'interfaccia `eth0` e la configurazione IP identica a quella di produzione.
- `SR-VRF-03` **(Readiness Probes e Timeout)**: Esecuzione di controlli di readiness con tentativi periodici sottoposti a timeout, prima della verifica effettiva.
- `SR-VRF-04` **(Zero Side-Channel)**: Confinamento rigoroso dell'ambiente di test allo switch virtuale isolato per impedire sniffing del traffico di exploit ed accesso da parte dei giocatori.
- `SR-VRF-05` **(Rilascio Delle Risorse Categorico)**: Deallocazione in ordine inverso (LIFO) di tutte le risorse allocate al completamento della verifica o in caso di errore.

3.3.5 Control Plane, Concorrenza e Persistenza

- `SR-CON-01` **(Two-Tier Lock)**: Meccanismo di lock gerarchico a due livelli (in-process ed inter-process) per prevenire mutazioni concorrenti sulla stessa risorsa.
- `SR-CON-02` **(Self-Healing Automatico)**: Demone in background `LifecycleManager` che rilascia periodicamente (ogni 120 secondi) switch e container di verifica orfani con un periodo di tolleranza di 600 secondi.
- `SR-CON-03` **(Healthcheck & Telemetria)**: Endpoint di monitoraggio per liveness e readiness probe ed estrazione live di handshake e metriche di traffico dei peer WireGuard.
- `SR-CON-04` **(Persistenza Locale Asincrona)**: Memorizzazione dello stato e delle associazioni (team, macchine, peer e immagini) su database SQLite.
- `SR-CON-05` **(Rollback in caso di errore)**: Qualunque errore imprevisto durante la creazione di container o interfacce di rete innesca il rilascio delle risorse allocate.
- `SR-CON-06` **(Idempotenza Operativa)**: Le richieste di provisioning per risorse gia allocate non alterano lo stato del sistema e ne generano errori.
- `SR-CON-07` **(Autenticazione)**: L'accesso alle API deve essere validato tramite un token di accesso configurato dall'amministratore. Si vuole evitare che altre entita oltre al CTF Manager possano usare l'interfaccia di BlueAgent.

3.3.6 Pipeline Immagini Distrobuilder

- `SR-IMG-01` **(Definizione IaC Distrobuilder)**: Creazione dichiarativa di immagini per container di sistema a partire da file di definizione YAML.
- `SR-IMG-02` **(Identificazione e Caching Crittografico)**: Utilizzo dell'alias come chiave a catalogo e calcolo dell'hash crittografico della specifica YAML per identificare modifiche e riutilizzare immagini gia compilate.
- `SR-IMG-03` **(Compilazione Asincrona)**: Esecuzione delle fasi di build in background tramite worker asincrono.

3.4 Oracoli e Meccanismi di Verifica

Per decidere se un team ha recuperato la **flag**, bisogna definire un'***oracolo***, che determini lo stato in cui si trova il sistema target.

L'oracolo e' in grado di accedere al sistema e di fare due azioni: puo' leggere la memoria fisica di qualsiasi nodo e puo' eseguire comandi su qualsiasi nodo

Per ogni tipo di azione eseguita, l'oracolo determina lo stato del sistema confrontando il risultato dell'azione con il valore che l'oracolo si aspettava (ossia i valori

vengono validati). In BlueAgent, l'oracolo e' l'entita che esegue sui container clonati i comandi specificati dall'Autore della sfida, ossia nel codice la classe `OVNVerifier`.

Dunque all'iterno del processo di verifica, il sistema si puo' definire *patchato* se e soltanto se tutte le azioni sono validate rispetto al valore che ci si aspettava in output.

Di seguito sono discussi alcuni meccanismi di verifica che abbiamo identificato, al fine di motivare la clonazione dei container implementata in BlueAgent.

3.4.1 Verifica Statica

La verifica statica prevede che l'oracolo possa accedere alla memoria fisica, comparando le patch applicate nei file in memoria, ad una patch considerata di riferimento per l'oracolo.

Questo tipo di verifica puo' essere implementato in vari modi:

- **diff**: ad ogni file interessato corrisponde un file di riferimento per l'oracolo. Ogni file viene dunque confrontato, riga per riga, con il suo riferimento per determinare se il team ha applicato la patch correttamente.
- **SAST**: Static Analysis Security Testing. Prevede l'accesso al codice sorgente non compilato in modo da analizzare pattern di codice vulnerabili e fallace logiche.[2]

Tuttavia, SAST non e' un metodo di analisi efficace, sebbene efficiente:

- possono essere identificati nel processo di verifica, vari falsi positivi (e falsi negativi)[2]
- non posso identificare staticamente tutti i tipi di errori di sicurezza [2]
- non posso identificare vulnerabilita all'interno dei binari compilati[2]

Dunque l'analisi statica puo' in alcuni casi risultare inesetta, e non coprire tutti i casi d'uso per quanto riguarda la gestione di competizioni CTF.

3.4.2 Verifica Dinamica tramite sistema esterno

Questo meccanismo di verifica prevede l'uso di un **orchestratore esterno** alle macchine vulnerabili, ossia l'attaccante, che possa interagire con la vulnerabilita utilizzando la rete locale. L'attaccante orchestra l'esecuzione di uno o piu comandi, con l'obiettivo di inviare il payload all'interno di un pacchetto di rete.

Durante una competizione di questo tipo, tuttavia, i membri dei team sono legittimati ad accedere alla macchina vulnerabile come utente `root`: cosi da permettere

[2]https://aetic.theiaer.org/archive/v4/v4n3/p1.html 2. Currrent Status of SAST based on Checkmarx

l'applicazione delle patch sui file di sistema. Questo implica che i partecipanti dei team siano in grado di eseguire tool come `tcpdump` e `wireshark` per intercettare il traffico di rete e di conseguenza, di visualizzarne il payload, ottenendo un suggerimento per la soluzione della challenge.

Inoltre, il payload inviato potrebbe essere tale da mandare in crash il servizio target, causando una penalita alla percentuale di **SLA** *(Service Level Agreement)*, ed interferendo potenzialmente con il lavoro del team sfidante (portando per esempio alla perdita di alcuni file). Si vuole dunque trovare un sistema di verifica che esegua completamente all'oscuro del team sfidante.

Il sistema di verifica tramite sistema esterno non copre nemmeno tutte le vulnerabilita. Banalmente, non tutti i servizi vulnerabili sono esposti in rete, ma sono accessibili solo in locale.

Riassumendo quindi, abbiamo identificato alcuni spunti per ideare un meccanismo di verifica migliore:

- Il traffico di rete non dovrebbe essere letto dal team sfidante al fine di ottenere suggerimenti per la soluzione.
- Se l'exploit manda in crash il servizio, questo non dovrebbe penalizzare il team, o piu in generale: il team sfidante non vede il servizio distruggersi.
- Dobbiamo gestire anche vulnerabilita non esposte in rete.

3.4.3 Verifica Dinamica tramite injection dei comandi di verifica

Questo meccanismo di verifica prevede l'uso di un **orcehstratore esterno** al sistema vulnerabile, che ha la facolta di eseguire comandi all'interno delle macchine vulnerabili che compongono il sistema. Dunque l'orchestratore esegue uno o piu comandi con il fine di verificare che il sistema sia resistente alla vulnerabilita.

Considerando il caso in cui una macchina `A` contenga un file binario vulnerabile ad un *buffer overflow*, l'orchestratore potrebbe eseguire ad esempio il comando `/path/to/service_logger payload` e verificare l'esito dell'esecuzione.

L'esecuzione di questi comandi e' possibile per esempio in ambienti containerizzati, sfruttando utility come `docker exec` o `incus exec`, che permettono di iniettare comandi all'interno dei container.

Tuttavia: comandi come `pspy`, (che ascoltano attivamente le chiamate di sistema effettuate e gli eventi sul file system in `/proc`) possono intercettare l'esecuzione dei comandi dell'orchestratore e di mostrarli al team, suggerendo al team sfidante la soluzione. [3]

Dunque, dobbiamo ideare un meccanismo di verifica che deve sia completamente invisibile a questi meccanismi di intercettazione.

[3] https://github.com/DominicBreuker/pspy

3.4.4 Clonazione del sistema in una rete separata

Clonare i container all'interno di una rete separata ed inaccessibile ai giocatori e' una soluzione plausibile in quanto:

- Isola la rete rispetto alla rete dei giocatori. I giocatori non possono intercettare il traffico di rete.
- I giocatori, per design, non hanno accesso ai container duplicati dunque non possono eseguire alcun tipo di comando.

Tutta via introduce un costo in termini di storage e di utilizzo della RAM dovuto alla duplicazione dei container, anche se questi esistono solo per il tempo necessario all'esecuzione dei comandi definiti dal creatore della sfida. Questo aspetto verra misurato piu avanti e sara oggetto di analisi.

Altri meccanismi di verifica ed architetture di rete possibili sono analizzati nel Capitolo 6.

Capitolo 4

Architettura Rete Alto Livello

La topologia di rete di Blue Agent e' suddivisa logicamente in due reti:

- **Una rete di produzione per ogni team**, dove la rete production-k identifica gli oggetti di rete ed i container necessari al team k.
- **Al piu' una rete di verifica per ogni team**, dove la rete verify-k identifica gli oggetti di rete ed i container duplicati utilizzati per la verifica richiesta dal team k.

Lo schema di indirizzamento prevede una netta separazione tra lo spazio di gioco del team k, la rete WireGuard e la rete di Incus:

- `10.k.0.0/24`: e' la sottorete WireGuard per i membri del team k.
- `10.k.1.0/24`: e' la sottorete LAN per i container di produzione e per i cloni di verifica.
- `172.16.0.0/24`: e' la sottorete gestita da incusbr0 per fornire la connettività esterna e le reti OVN tramite NAT.

4.1 Rete production-k

La rete production-k e' fatta cosi, contiene:

- wg-k: dispositivo L3 gestito da WireGuard, fa da terminazione per il tunnel del team k-esimo. Ha come IP gateway: `10.k.0.1/24`
- br-team-k: dispositivo L2 gestito dal kernel Linux. Ha come IP gateway: `10.k.1.1/24`
- eth0: le interfacce di rete eth0 dei container che vengono collegate a br-team-k.

wg-k serve per fornire ai membri del team k l'endpoint per la connessione tramite VPN, in questo modo i membri del team saranno connessi direttamente alla rete production-k. Ogni membro ha la sua configurazione WireGuard associata al suo

peer impostato sull'interfaccia wg-k. Aggiungere un peer all'interfaccia WireGuard significa permettere ad un client con una certa chiave pubblica di collegarsi con un certo indirizzo ip (**cryptokey routing**), e quindi assegnare ad ogni membro del team `k` un indirizzo nella sottorete `10.k.0.0/24`.

L'interfaccia br-team-k permette di creare una rete LAN per i container del team k, a cui questi si collegano definendo direttamente un dispositivo NIC bridged per ciascun container.

Questo collegamento avviene tramite l'utilizzo di una `veth pair` (Virtual Ethernet) per container: una estremita e' collegata a `br-team-k`, l'altra all'interfaccia del container `eth0`. Dunque all'interno del kernel appesantiamo il carico nella gestione delle interfacce, infatti avremmo oltre ad `eth0`, una coppia `veth` per ogni container.

> `veth`: E' utile per collegare interfacce che risiedono per esempio su differenti Network Namespace (ossia il modo in cui sono implementati i container). Utilizzano poca CPU e poca memoria, dato che l'implementazione risiede direttamente nel kernel. Dunque per centinaia di `veth` non si ha un degrado evidente delle prestazioni. [1]

Tramite regole di forwarding del kernel e di firewall via `nftables`, il traffico dell'interfaccia wg-k viene autorizzato verso br-team-k e viceversa. Questa regola viene applicata aggiungendo dentro al set `team_links` (una struttura dati all'interno del kernel gestita da nftables) la coppia di interfacce interessate.

4.2 Rete verify-k

La rete verify-k e' fatta cosi, contiene:

- verify-k: rete virtuale logica gestita via SDN tramite OVN e orchestrata da Incus [2]. Non costituisce una singola interfaccia di rete convenzionale del kernel, ma una topologia virtuale isolata composta da uno switch e un router con gateway: `10.k.1.1/24`.
- incusbr0: bridge di rete di Incus con gateway `172.16.0.1/24`. Svolge il ruolo di interfaccia per l'instradamento verso l'esterno della rete OVN.
- eth0: sono le interfacce di rete dei container clonati (`10.k.1.x`) che vengono collegate a verify-k.

  > Incus e' in grado di gestire da solo il collegamento tra incusbr0 ed verify-k. Questo semplifica di molto la gestione delle interfacce di verifica per BlueAgent.

[1] https://dev.to/godofgeeks/virtual-ethernet-devices-veth-ofd

[2] Documentazione ufficiale Incus, OVN network driver: https://linuxcontainers.org/incus/docs/main/reference/netw

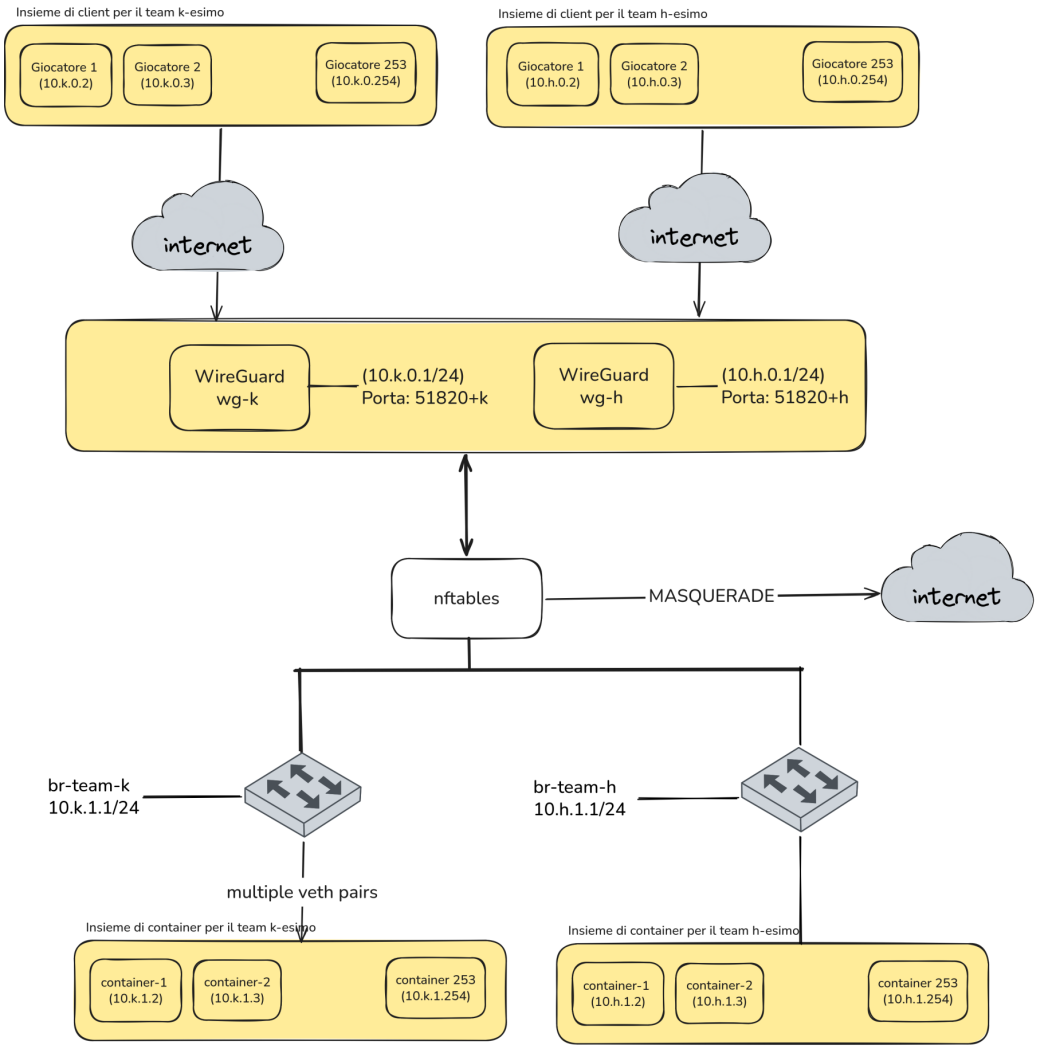


Figura 4.1: Production Network

Le interfacce dei container e la rete verify-*k* sono gestite dalla SDN (*Software Defined Network*). verify-*k* e' implementata da:

1. un **Logical Switch** (denominato internamente da Incus nel DB di OVN come `incus-net<ID>-ls-int` [2]): rappresenta la LAN su cui si agganciano le interfacce virtuali dei container di verifica.
2. un **Logical Router** (denominato `incus-net<ID>-lr` [2]): agisce come gateway (`10.k.1.1/24`), permettendo ai container clonati di preservare l'identica configurazione IP rispetto alla produzione.

   Tunneling Geneve e considerazioni sull'MTU: OVN impiega il protocollo di tunneling **Geneve** (*Generic Network Virtualization Encapsulation*) [3] per spostare i pacchetti tra piu nodi della rete.

L'incapsulamento Geneve introduce tuttavia un overhead di intestazione di 58 byte, riducendo l'MTU effettiva della rete di verifica a 1442 byte (rispetto ai 1500 byte standard). Se pacchetti di dimensione eccedente hanno il flag *Don't Fragment* (DF) abilitato, rischiano di essere scartati generando un fenomeno di *Path MTU Blackhole*. Questo problema viene risolto forzando il *clamping* del MSS per il traffico TCP via `nftables` [4], mentre il traffico UDP deve rimanere entro i limiti imposti dall'MTU.

Bisogna notare che il tunnel Geneve non viene mai utilizzato, poiche i container di verifica risiedono tutti all'interno dello stesso nodo. Tuttavia Incus limita di default l'MTU delle interfacce di rete dei container a 1420 byte per precauzione (in caso di una rete OVN con tunnel) e per risolvere il problema del *Path MTU Blackhole* nella rete di verifica e' possibile forzare l'MTU a 1500.

L'uso di una SDN garantisce l'assenza di conflitti di routing grazie a una netta separazione tra **spazio utente** e **spazio kernel** [5]:

- **Spazio Utente (Control Plane):** i demoni di controllo di OVN (`ovn-controller`, `ovn-northd`) e di Open vSwitch (`ovs-vswitchd`) elaborano la topologia logica e la traducono in flussi OpenFlow. Il router OVN esiste puramente a livello logico.
- **Spazio Kernel (Data Plane):** qui viene applicato l'inoltro dei frame ad alte prestazioni tramite il modulo kernel di Open vSwitch.

Il collegamento tra i container e la rete OVN sfrutta sempre una coppia `veth`: un'estremità risiede all'interno del container e si attacca ad `eth0`, mentre l'altra estremità sull'host viene agganciata direttamente al bridge di Open vSwitch.

[3] Documentazione architetturale OVN e Geneve: https://docs.ovn.org/en/latest/topics/geneve.html

[4] Documentazione Netfilter, TCP MSS Clamping: https://wiki.nftables.org/wiki-nftables/index.php/Forwarding_traffic

[5] Documentazione Open vSwitch, architettura Datapath Kernel vs Userspace: https://docs.openvswitch.org/en/latest/intro/what-is-ovs/

`SDN (Software Defined Networking)`: Paradigma architetturale che separa il **piano di controllo** dal **piano dei dati**, consentendo di gestire e programmare l'infrastruttura di rete interamente via software.

`OpenFlow`: Protocollo standard che permette al controller SDN di comunicare con lo switch e programmare le regole di matching e le azioni direttamente all'interno delle pipeline di Open vSwitch.

`OVN (Open Virtual Network)`: Sistema SDN che opera come Control Plane per Open vSwitch. Traduce topologie logiche (Logical Switch, Logical Router, NAT e ACL) in flussi OpenFlow distribuiti, istruendo Open vSwitch su come instradare il traffico senza creare molteplici interfacce o bridge dedicati nel kernel host. E' costituito da due interfacce: **OVN Northbound**: e' l'interfaccia dove dichiaro le reti che voglio creare e le loro proprietà che devono rispettare. **OVN Southbound DB:** Memorizza le tabelle di flussi logici compilate e le associazioni di chassis (host fisici).

La comunicazione verso l'esterno avviene collegando il Logical Router OVN al bridge parent incusbr0, da cui ottiene un indirizzo IP da utilizzare. L'accesso a Internet per i container di verifica sfrutta un meccanismo di NAT a due stadi:

- **SNAT in OVN**: quando un container (`10.k.1.x`) invia traffico all'esterno, il Logical Router riscrive l'indirizzo sorgente sostituendolo con l'IP uplink assegnato su `incusbr0`. Se non fosse applicato, i pacchetti in uscita manterrebbero l'indirizzo sorgente `10.k.1.x` e le risposte dall'esterno verrebbero erroneamente instradate verso l'ambiente di produzione.
- **SNAT su `incusbr0`**: una volta raggiunto `incusbr0`, le regole `nftables` dell'host applicano la regola di **masquerade** verso l'interfaccia fisica per uscire su Internet.

Il NAT a due stadi e' necessario per evitare collisioni di routing sull'host: il primo stadio "nasconde" gli indirizzi duplicati `10.k.1.x` traducendoli in un IP univoco sull'infrastruttura `172.16.0.0/24`, mentre il secondo stadio permette la navigazione esterna condividendo l'IP dell'host.

`NAT (Network Address Translation)`: Meccanismo di rete che modifica le informazioni di intestazione IP (e opzionalmente le porte di livello 4) dei pacchetti in fase di routing. [6].

[6]Documentazione Netfilter, Network Address Translation (NAT): https://wiki.nftables.org/wiki-nftables/index.php/Performing_Network_Address_Translation_(NAT)

`SNAT (Source NAT)`: Variante del NAT applicata al traffico uscente (**egress**, fase di postrouting). Modifica l'indirizzo IP sorgente del pacchetto con un indirizzo pubblico o instradabile dalla rete esterna.

`Masquerading`: Variante dinamica di `SNAT`. Si ha quando l'indirizzo sorgente viene mappato dinamicamente sull'IP dell'interfaccia di uscita dell'host.

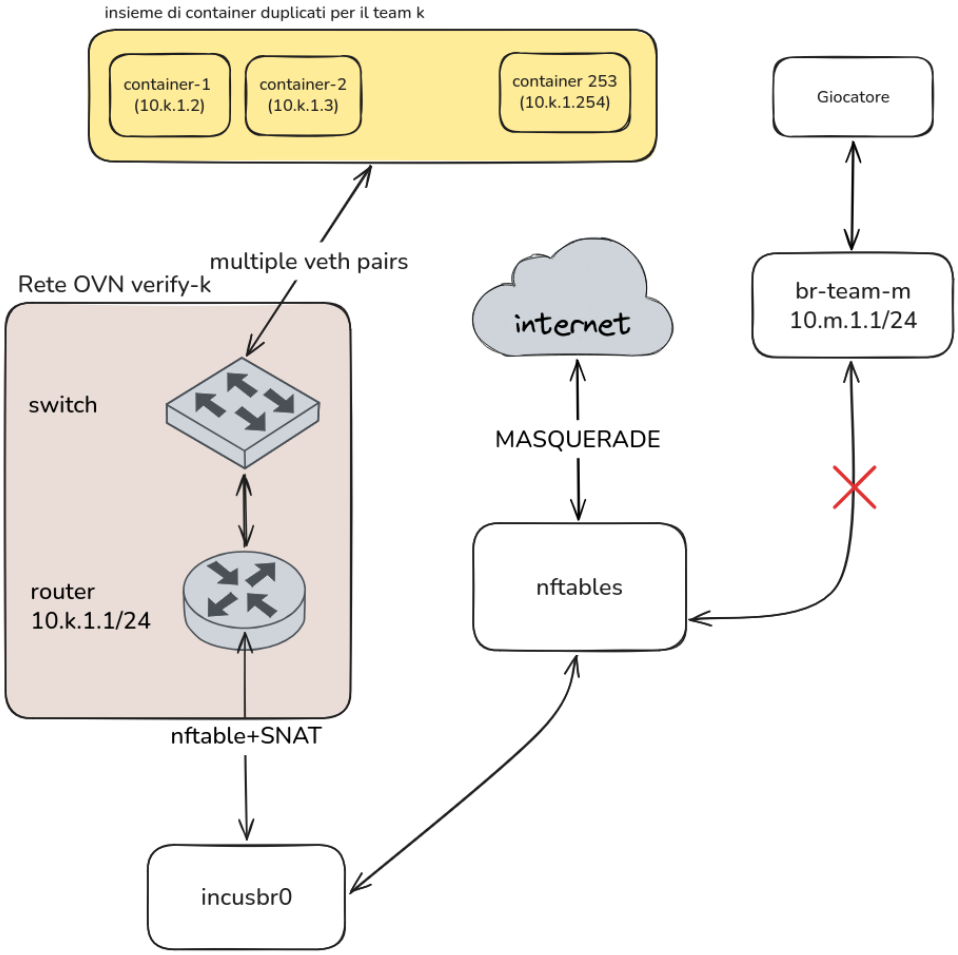


Figura 4.2: Verify Network

4.3 Struttura di una Challenge

Capitolo 5

Architettura Nel Dettaglio e Validazione

5.1 Architettura del Codice

A livello software, BlueAgent organizza l'interazione con l'host disaccoppiando l'API in `/api` dalla gestione a basso livello dei container e delle componenti di rete, gestita ad alto livello dai servizi in `/services`, che contiene la logica di business, mentre le complessità operative sono delegate a moduli e driver specializzati (come `/engine`, `/network`, `/verifier`, `/images` e `/lifecycle`).

5.1.1 Astrazione del Runtime: `ContainerEngine`

BlueAgent non invoca direttamente il demone Incus all'interno della logica delle challenge. Tutte le operazioni di gestione del ciclo di vita dei container sono intermediate da un'interfaccia astratta denominata `ContainerEngine`.

Questa classe astratta formalizza esclusivamente le primitive necessarie ai requisiti operativi del Cyber Range:

- Creazione, avvio, arresto forzato ed eliminazione delle istanze.
- Duplicazione rapida e gestione delle interfacce di rete.
- Esecuzione dei comandi nei container.

Disaccoppiare l'interfaccia dall'implementazione permette ai servizi di non dover conoscere come avviene la gestione dei container, e di predisporre il codice per poter utilizzare altri gestori.

> **ATTENZIONE: anche la generazione delle immagini dovrebbe avvenire tramite interfaccia**

L'implementazione concreta `IncusEngine` comunica con il demone di sistema tramite Unix Domain Socket (`/var/lib/incus/unix.socket`), traducendo le primitive astratte in chiamate REST HTTP asincrone.

> `Unix Domain Socket (UDS)`: Meccanismo di Inter-Process Communication (IPC) gestito interamente dal kernel del sistema operativo. La comunicazione avviene trasferendo i dati direttamente tra i buffer di memoria dei processi nello spazio kernel senza attraversare lo stack di rete. L'endpoint è rappresentato da un file speciale sul filesystem (es: `/var/lib/incus/unix.socket`).[1]

5.1.2 Ciclo di Vita della Sandbox: Async Context Manager (`OVNVerifier`)

Il processo di verifica richiede di istanziare una replica fedele della rete di produzione che deve esistere esclusivamente per la durata dei test. In caso di qualsiasi tipo di fallimento, l'infrastruttura clonata deve essere rilasciata per evitare risorse allocate e sprecate.

Per garantire questa proprietà, il ciclo di vita della sandbox è incapsulato all'interno della classe `OVNVerifier`, implementata come **Asynchronous Context Manager** di Python.

> **Pattern RAII (Resource Acquisition Is Initialization):** L'allocazione delle risorse è vincolato dall'acquisizione del contesto, mentre il loro rilascio e smantellamento deterministico è garantito all'uscita dal blocco, gestendo automaticamente qualsiasi anomalia o interruzione. [2]

Il ciclo di vita dell' `OVNVerifier` segue tre fasi:

1. **Inizializzazione (`__aenter__`):**
   - Creazione della rete OVN temporanea
   - Duplicazione dei container tramite snapshot ZFS
   - Riconnessione dell'interfaccia `eth0` dei cloni alla nuova rete OVN
   - Istanziazione opzionale del container *Verifier Runner*.
2. **Esecuzione delle Verifiche (`run_checks`):**
   - Esecuzione controllata dei comandi di test con timeout
3. **Rilascio e Teardown (`__aexit__`):**

[1] Linux manual page, unix(7) - Sockets for local interprocess communication: https://man7.org/linux/man-pages/man7/unix.7.html

[2] Bjarne Stroustrup, Resource Acquisition Is Initialization (RAII), C++ Programming Language.

1. Arresto ed eliminazione del container `verify-runner`;
2. Arresto forzato ed eliminazione di tutti i container cloni;
3. Eliminazione della rete virtuale OVN.

L'uso dell'**Async Context Manager** fornisce dunque un metodo sicuro per utilizzare l'oggetto `OVNVerifier`.

5.1.3 Concorrenza e Two-Tier Locking

Incus non supporta operazioni concorrenti sul medesimo container. Inoltre per evitare problemi di accesso alle risorse e' opportuno implementare un sistema di lock.

BlueAgent implementa un meccanismo di sincronizzazione a due livelli (`TwoTierLock`), dove sequenzialmente si richiede un tier dopo l'altro:

- **Tier 1 (Intra-processo):** utilizza `asyncio.Lock` per effettuare il lock delle risorse all'interno di un singolo processo.
- **Tier 2 (Inter-processo):** applica un lock non bloccante sul filesystem (`fcntl.flock`) condiviso tra piu processi

Questo lock protegge l'accesso alle risorse in due casi:

- BlueAgent esegue su un solo processo (worker), ma le richieste potrebbero essere gestite da piu task contemporaneamente. Allora il lock Tier 1 protegge l'accesso alla stessa risorsa da parte di due task sullo stesso worker.
- BlueAgent esegue su piu processi (worker), allora il lock Tier 2 protegge l'accesso alla stessa risorsa da parte di due task su worker differenti.

  Come si avviano piu' worker? `uvicorn main:app --workers 4`

  `uvicorn`: e'il web server su cui si basa FastAPI, dunque e' uvicorn che decide come gestire le richieste, e a quali task e worker assegnarli. Da solo FastAPI non funziona, non implementa il server di rete.

Questa architettura protegge le risorse sia a livello di singolo processo sia in caso di server multi-worker, garantendo mutua esclusione sulle mutazioni su tutti i tipi di risorse.

La risorsa principale su cui avviene la mutua esclusione nel codice e' il team. Qualsiasi operazione sul team k genera un lock a 2 tier per quel team.

5.1.4 Pipeline Asincrona non Bloccante su Socket Unix

Le operazioni di incus su container possono comportare latenze nell'ordine di decine o centinaia di millisecondi. L'adozione di un modello sincrono sarebbe totalmente inefficiente.

BlueAgent è progettato secondo un paradigma completamente asincrono in modo da adattarsi al metodo `wait` di Incus:

- `IncusEngine` comunica con il socket UDS locale (`/var/lib/incus/unix.socket`) per mezzo di `httpx.AsyncClient`.
- Poiché le operazioni bloccanti di Incus sono gestite in background, BlueAgent interroga asincronamente l'endpoint `/1.0/operations/<uuid>/wait` per sapere quando l'operazione viene rilasciata.

Inoltre, l'esecuzione dei comandi sulla macchina host avviene tramite `asyncio.create_subprocess_exec` all'interno del runner asincrono, evitando chiamate bloccanti sul loop principale ed esecuzione di shell non sicure.

Questo approccio consente a un singolo processo BlueAgent di servire le richieste di telemetria utilizzando piu task e senza rimanere in attesa su una singola richiesta evitando di servire le altre richieste.

5.2 Comandi per l'Architettura di Rete

Per andare a fondo nei dettagli implementativi e spiegare meglio alcuni concetti, sono riportati alcuni passaggi fondamentali nella configurazione della rete dell'host che esegue BlueAgent, o di comandi eseguiti direttamente da BlueAgent.

5.2.1 Configurazione OVN e Open vSwitch

Qui riporto la configurazione per implementare la SDN. Il **piano dei dati** e' implementato da Open vSwitch (**OVS**) e deve esser configurato in modo che possa comunicare con Incus tramite l'interfaccia di OVN

Si configura OVS in modo che possa comunicare con l'interfaccia south bound di OVN (`ovnsb_db.sock`):

```
sudo ovs-vsctl set open_vswitch . \
    external_ids:ovn-remote=unix:/run/ovn/ovnsb_db.sock \
    external_ids:ovn-encap-type=geneve \
    external_ids:ovn-encap-ip=127.0.0.1
```

- `ovn-encap-type=geneve`: Specifichiamo Geneve come protocollo da utilizzare per il tunneling. Questo passaggio e' necessario anche se non utilizziamo mai Geneve
- `ovn-encap-ip=127.0.0.1`: Imposta la terminazione del tunnel nel localhost.

Si configura invece l'interfaccia North Bound in modo che possa comunicare con Incus:

```
ovn-nbctl set-connection ptcp:6641:127.0.0.1
incus config set network.ovn.northbound_connection tcp:127.0.0.1:6641
```

OVN Northbound: e' l'interfaccia dove dichiaro le reti che voglio creare e le proprietà che devono rispettare. **OVN Southbound DB:** memorizza le tabelle di inoltro e la logica da applicare sul piano dei dati.

5.2.2 production-k Routing e Connettività dei Peer (WireGuard e nftables)

L'accesso dei partecipanti ai container rete production-k richiede l'applicazione di regole di inoltro esplicite tra `wg-k` ed `br-team-k`, da applicare nel kernel Linux mediante `nftables`.

Le regole per il traffico vengono definite dentro la tabella `inet blueagent`:

```
sudo nft add table inet blueagent
sudo nft add set inet blueagent team_links '{ type ifname . ifname; flags interval; }'

sudo nft add element inet blueagent team_links { "wg-$k" . "br-team-$k", "br-team-$k" .
    "wg-$k" }
```

All'interno della catena `forward`, prima di accettare il traffico, viene forzato il *clamping* del MSS per il traffico TCP per prevenire blackhole dovuti alla riduzione di MTU dei tunnel. Subito dopo, il traffico lecito tra membri e container dello stesso team viene autorizzato verificando l'appartenenza al set `@team_links`:

```
sudo nft add chain inet blueagent forward '{ type filter hook forward priority filter;
    policy accept; }'
sudo nft add rule inet blueagent forward tcp flags syn / syn,rst tcp option maxseg size
    set rt mtu
sudo nft add rule inet blueagent forward iifname . oifname @team_links accept
```

A priori, si vuole impedire l'inoltro dei pacchetti applicando l'azione `drop` tra le interfacce `wg` e `br-team` non autorizzate, in modo da bloccare rotte e comunicazioni incrociate non esplicitamente accettate nella tabella:

```
sudo nft add rule inet blueagent forward iifname "wg-*" oifname "br-team-*" drop
sudo nft add rule inet blueagent forward iifname "br-team-*" oifname "wg-*" drop
sudo nft add rule inet blueagent forward iifname "br-team-*" oifname "br-team-*" drop
sudo nft add rule inet blueagent forward iifname "wg-*" oifname "wg-*" drop
sudo nft add rule inet blueagent forward iifname "br-team-*" accept
sudo nft add rule inet blueagent forward oifname "br-team-*" ct state
    established,related accept
```

Per consentire l'accesso a Internet ai container e ai peer, viene applicato il mascheramento dell'indirizzo sorgente. Si deve dunque abilitare il `nat` (il meccanismo di traduzione degli indirizzi) poco prima che il frame esca e venga immesso fisicamente sulla porta. Infine si specifica che si applica il nat dinamico (`masquerade`) per gli indirizzi che provengono dalla rete dei container verso l'esterno.

```
sudo nft add chain inet blueagent postrouting '{ type nat hook postrouting priority
    srcnat; policy accept; }'
sudo nft add rule inet blueagent postrouting ip saddr 10.0.0.0/8 ip daddr != 10.0.0.0/8
    masquerade
```

5.3 Plugin CTFd

5.4 Validazione

Illustreremo e commenteremo adesso le performance testando BlueAgent. Per tutti i test e' stato eseguito BlueAgent all'interno di una macchina virtuale con a disposizione 8 Core Ryzen 7700X, 16GB RAM 5600MHz e la pool ZFS all'interno di un SSD.

I test effettuati si occupano di richiedere e misurare il tempo richiesto per le seguenti fasi:

- B1: Provisioning per M team.
- B2: Deploy di C container per ogni team.
- B3: Lancio della verifica per ogni team
- B4: Teardown dell'ambiente di verifica
- B5: Teardown delle macchine
- B6: Teardown delle infrastrutture dei team.

Per assicursi sincronia nelle misurazioni, il test e' stato organizzato in barriere $B1, \ldots, B6$. Per superare una barriera si attende che tutte le operazioni sulle risorse siano completate, cosi da vitare misurazioni errate.

Ad ogni banda vengono eseguite una serie di richieste HTTP verso BlueAgent mentre ogni 100ms si campiona il contenuto di `/proc/stat` per ottenere:

- $\text{CPU}_{\text{util}} = \Delta(\text{user} + \text{system} + \text{nice})/\Delta\text{total} \times 100$
- $\text{IO}_{\text{wait}} = \Delta\text{iowait}/\Delta\text{total} \times 100$

spiega che vordi sta roba

Per ottenere l'uso della RAM invece sono stati campionati `/proc/meminfo` e `/proc/spl/kstat/zfs/arcstats` per ottenere:

- $\text{RAM}_{\text{usata_grezza}} = \text{MemTotal} - \text{MemFree} - \text{Buffers} - \text{Cached}$
- $\text{RAM}_{\text{netta_container}} = \text{RAM}_{\text{usata_grezza}} - \text{ARC}_{\text{size}} - \text{RAM}_{\text{baseline}}$

spiega che vordi sta roba

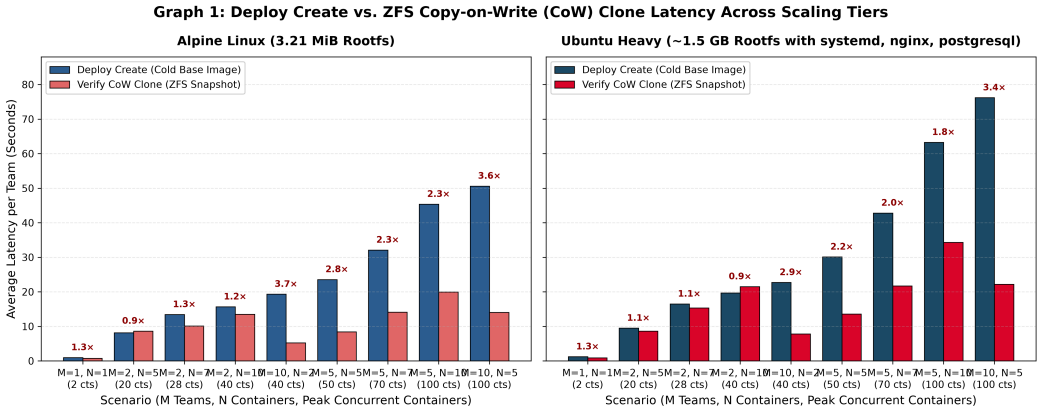


Figura 5.1: Graph1 Cow Vs Deploy

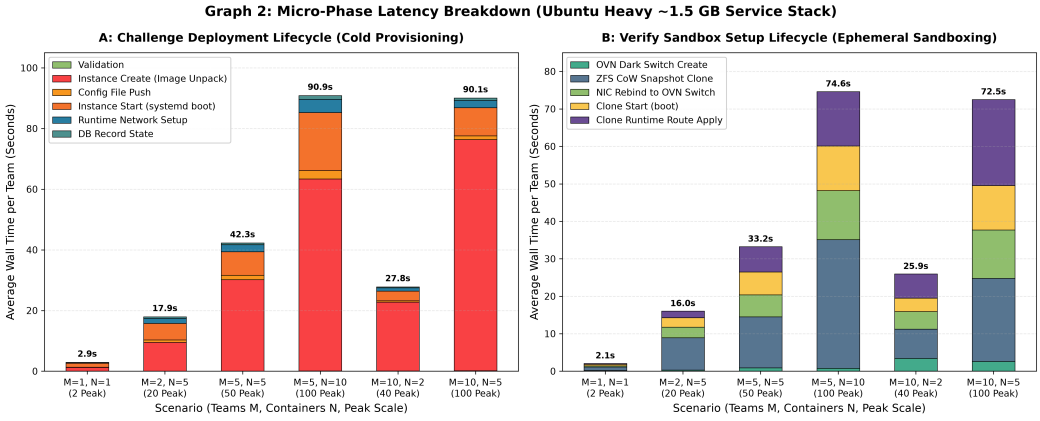


Figura 5.2: Graph2 Microphase Breakdown

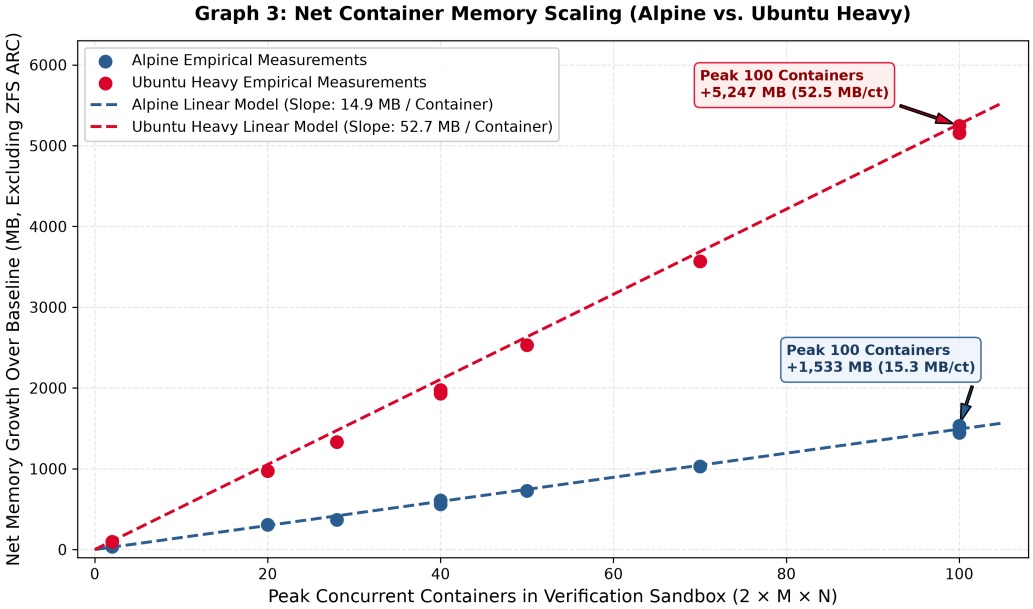


Figura 5.3: Graph3 Memory Scaling

5.5 Difesa e Validazione di BlueAgent

Come Sistema Operativo su cui basare lo sviluppo e' stato scelto **Debian 13**, in quanto offre un kernel stabile ed un'ottima compatibilita tra i vari pacchetti e le componenti utilizzate da BlueAgent.

Su questo sistema operativo si e' scelto di utilizzare ZFS per creare la pool per le immagini dei container. ZFS offre il meccanismo CoW a basso costo, ed e' stato scelto rispetto ad alternative come BTRFS poiche, ZFS e' ritenuto più maturo e stabile. Si benefica da CoW in 2 scenari, quando si effettua il deploy della challenge per un team e quindi l'immagine deve essere prelevata dalla pool ed per il provisioning instantaneo.

L'adozione di Incus e' dovuto alla necessita di dover offrire ai giocatori delle macchine realistiche attraverso i system containers, che offrono un proprio init system ed un processo `init` con `PID` 0. Permette dunque ai giocatori di operare realisticamente accedendo a varie utility di sistema e di installare pacchetti. Incus gestisce nativamente pool `ZFS` e le reti OVN semplificando il codice di BlueAgent.

Il vantaggio piu grande che porta BlueAgent e' l'invisibilita totale dei giocatori rispetto all'Oracolo, ribadiamo dunque che e' impossibile per i partecipanti intercettare ed ascoltare traffico di rete poiche l'interfaccia `verify-ovn-k` esiste solo logicamente ed instrada verso `incusbr0`. In `nftables` invece le rotte autorizzate permettono l'instradamento solo tra `wg-k` ed `br-team-k`

Inoltre usare il meccanismo CoW riduce notevoilmente il tempo iniziale richiesto per eseguire il setup dei container mentre l'uso di OVN facilita la configurazione di

rete.

Nonostante i vantaggi, l'architettura presenta dei compromessi:

- **MTU Blackhole per UDP:** il traffico tra giocatore e container attraversa il tunnel WireGuard, con MTU1420. Mentre il problema viene risolto per TCP tramite l'MSS clamping, i pacchetti UDP con flag *Don't Fragment* potrebbero essere scartati dal kernel in caso i pacchetti assumano una MTU pari a 1500 come in Ethernet.
- **Limite di scalabilità a 254 team:** L'indirizzamento deterministico `10.k.x.x` vincola k a un singolo byte ($0 \leq k \leq 254$), quindi ad un massimo di 255 team.
- **Concorrenza e blocco multi-nodo:** Il meccanismo `TwoTierLock` (`asyncio.Lock` combinato con `flock`) puo funzionare solo se BlueAgent e' confinato al singolo nodo. Per scalare l'architettura ed avere istanze di BlueAgent su più nodi bisogna introdurre l'uso di un gestore di lock distribuito come Redis.
- **Flessibilita'**: BlueAgent sceglie volontariamente di non sfruttare Ansible e Kubernetes per mantenere l'infrastruttura leggera e per dipendere il meno possibile da software esterni. Tuttavia, l'assenza di questi software rende BlueAgent poco flessibile ed adattabile, rendendo necessario molto lavoro nel codice sorgente per renderelo adattabile a seconda degli scenari da simulare.

Capitolo 6

Architetture Rete Alternative

6.1 Bridge L2 Senza Gateway

Questa architettura prevede solo la creazione di un bridge L2, per istanziare una rete LAN virtuale sui cui attaccare i container da verificare. I container duplicati mantengono la topologia di rete invariata, e possono comunicare tra di loro, tutta via il bridge L2 non ha un gateway verso cui instradare per accedere alla WAN. Dunque al livello 3 i container non possono essere visti dall'esterno della LAN.

Questa architettura e' molto semplice da implementare ed e' anche efficiente, in quanto fa uso solo di strutture dati primitive del kernel linux e di solo un'unico bridge.

Tutta via rende impossibile per i container l'instradamento verso l'esterno della rete. Dunque, dall'interno dei container di verifica, comandi come `apt`, e `ping` verso host esterni falliranno.

Questa architettura e' perfetta per vulnerabilità e script di verifica che non hanno bisogno di accedere ad internet. Immaginando pero' che per qualsiasi motivo, internet potesse essere fondamentale, anche in fase di verifica, si e' scelto di scartare questa opzione.

6.2 Interfaccia wan1 Aggiuntiva

Riprendendo l'architettura descritta in 6.1, per provare ad aggiungere la connettività ad internet senza assegnare un'indirizzo gateway L3 al bridge, e' possibile aggiungere ad ogni container duplicato, una interfaccia `wan1` per l'inoltro verso `incusbr0`.

Il problema di questa soluzione e' che necessita di alterare le regole di routing dei container, interferendo con le tabelle del Kernel ed eventualmente compromettendo la verifica dell'exploit, in caso questo si aspetti delle determinate regole di routing.

Inoltre e' una soluzione poco efficiente: richiede di duplicare manualmente il numero di interfacce previste (tenendo a mente che ogni coppia di interfacce richiede

una coppia di veth per la comunicazione con `incusbr0`). La soluzione sembra essere abbastanza macchinosa da implementare per cui e' stata scartata.

6.3 Network Namespace Separato per la Verifica

In BlueAgent, abbiamo introdotto OVN per semplificare la gestione di due reti con stesso gateway.

Per evitare di aggiungere la complessita computazionale di OVN, si puo' pensare di creare un network namespace separato al momento della verifica.

All'interno di questo nuovo namespace, chiamato verify-k si crea la rete di verifica composta dal solo bridge L2 e si assegna a questo bridge il gateway originale.

I container duplicati dovranno poi essere collegati al nuovo bridge.

Per consentire l'accesso alla rete WAN bisogna usare una coppia di `veth`, per collegare il namespace verify-k al namespace root.

In questo modo i due bridge con stesso ip gateway possono coesistere poiche riesiedono in namespace differenti, ci pensa il kernel ad effettuare il routing dei pacchetti verso le giuste interfacce nei differenti namespace.

Tutta via l'implementazione non e' immediata e l'uso di Incus non si sposa bene con la creazione di network namespace separati dato che non sa come tracciarene l'esistenza. Dunque bisogna gestire manualmente le interfacce di rete, aggiungendo una notevole complessita. Questo perche' il motore di Incus esegue sul namespace root, e non e' progettato per gestire interfacce dentro altri namespace. Bisogna dunque raggirare Incus, ed istanziare e gestire in BlueAgent coppie di *veth* che gestiscano questo disallineamento.

Dal lato del codice aumenta dunque la complessita: invece di fare richieste verso l'API di Incus per gestire le interfacce, bisogna usare vari comandi e tracciare il ciclo di vita delle interfacce usate.

6.4 Router Intermedio

Un'altra possibile alternativa consiste nell'introdurre un router dedicato (ad esempio un container Linux minimale) posto tra il bridge di verifica e l'interfaccia uplink `incusbr0`.

In questa architettura, i container duplicati vengono collegati a un bridge L2 isolato. Il router intermedio si aggancia su questo bridge assumendo l'indirizzo IP del gateway originale (`10.k.1.1/24`), permettendo ai container di verifica di preservare inalterata la propria topologia, la configurazione IP e le tabelle di routing.

Verso l'esterno, il router dispone di una seconda interfaccia agganciata ad `incusbr0`, su cui applica regole di SNAT per mascherare il traffico uscente. In questo modo

la topologia interna della rete di verifica viene completamente nascosta all'host e all'esterno, evitando i conflitti di instradamento con la rete di produzione.

L'architettura è concettualmente valida e pienamente fattibile, offrendo un isolamento efficace e un'elevata fedeltà dell'ambiente replicato. Tuttavia, sul piano operativo risulta leggermente più complessa rispetto alla soluzione adottata in BlueAgent con OVN.

Mentre con OVN la creazione dello switch, del router logico e delle regole di NAT è gestita in modo nativo e dichiarativo da Incus tramite API, l'uso di un router intermedio impone a BlueAgent di gestire manualmente l'intero ciclo di vita di un container ausiliario aggiuntivo per ogni sessione di verifica. Questo comporta una maggiore complessità nel codice di orchestrazione, un footprint di memoria leggermente superiore rispetto alla soluzione che sfrutta la SDN.

Capitolo 7

Appendice

7.1 Linux Networking

Per approfondire meglio il discorso relativo al routing dei pacchetti e delle interfacce di rete, si vuole elencare ad alto livello cosa succede all'interno del kernel linux e quali sono gli oggetti fondamentali.

7.1.1 Network Device Driver [1]

Un network device opera sempre livello 2 o 3 nello stack di rete, ed e' rappresentato nel kernel dalla struttura `net_device`. Questa struttura dati contiene varie informazioni:

- `IRQ`: numero identificativo del dispositivo
- `MTU`: la MTU del dispositivo
- `MAC`: MAC address del dispositivo
- `Nome`: `eth0`, `enp0s3`, `wlan0`, ecc...
- `net_device_ops`: contiene i puntatori alle funzioni per la gestione del dispositivo (come le primitive start, stop, transmit, receive)

Un device driver si occupa di:

- **Ricevere** i pacchetti destinati al local host, inoltrandoli al livello di rete, e successivamente al livello di trasporto.
- **Trasmette** i pacchetti generati dal local host, o fa il forward dei pacchetti ricevuti verso un'altra interfaccia.

Ogni pacchetto in transito in tutti e due i sensi scatena un lookup nel *sottosistema di routing*, che decide cosa bisogna fare con quel pacchetto. La fase di routing

[1] Linux Kernel Networking - Implementation and Theory

si distingue in 5 fasi, detti **hook**, dove possiamo registrare dei **callback** per il **sottosistema netfilter**.

Per esempio l'hook `NF_INET_PRE_ROUTING`, registra la chiamata al callback per essere eseguito prima che il lookup del sottosistema di routing venga effettuato. Il callback ritorna un verdetto sul filtraggio del pacchetto, decidendo se bisogna accettarlo (`NF_ACCEPT`), oppure scartarlo (`NF_DROP`).

> Con `nftables` applichiamo le regole di filtraggio dei pacchetti in modo da intercettare e manipolare il sottosistema di routing
>
> Oltre ai callback registrati, altri fattori influenzano il modo in cui il routing viene effettuato. Per esempio un pacchetto viene scartato quando il TTL viene diminuito e arriva a 0.

La struttura `sk_buff` (Socket Buffer) definisce come un pacchetto nel kernel Linux viene rappresentato e viene manipolato unicamante attraverso la SKB API.

La Socket Buffer viene allocata dinamicamente quando il pacchetto viene ricevuto sul cavo, ed e' la struttura dati utilizzata per manipolare il pacchetto nel kernel sui vari layer di rete.

All'interno del kernel la struttura dati responsabile per il sottosistema di routing e' la `fib_table`, ossia la tabella che raccoglie le rotte per il traffico destinato ad una certa sottorete.

7.1.2 Bridge [2]

Un bridge e' un dispositivo L2 che capisce il protocollo del livello di collegamento, effettua l'inoltro dei dati copiandoli frame per frame. Per farlo deve mantenere nel suo buffer almeno un frame per volta.

Un bridge assegna un'indirizzo al livello di collegamento ad ognuna delle sue interfacce ed effettua il forward verso di queste se il bridge non e' il destinatario del pacchetto. Opzionalmente puo' implementare il livello di rete (Layer 3) per offrire visibilita alle interfacce collegate e viene di solito utilizzato per unire due LAN diffrenti, o per creare una LAN.

Un bridge nel kernel Linux e' un device virtuale, finché non viene collegato ad altri device non puo' ne ricevere e ne trasmettere frame. Usa il concetto di enslaving: ossia le vengono assegnate delle interfacce dette **enslaved** da controllare.

Quando si tenta di trasmettere su un bridge (es: `br0`), il device driver gestisce i device **enslaved** effettuando il forwarding dei frame.

Posso eventualmente nell'host, assegnare un'indirizzo IP al bridge facendolo comportare come gateway per le interfacce collegate alle sue porte. Dunque un brdige puo' essere esteso per partecipare al Layer 3.

[2] Understanding Linux Networking Internals

7.1.3 Netfilter (Capitolo 5 e 9 IPV4 routing) [3] [4]

E' un sottosistema del kernel che fornisce le seguenti funzionalita all'interno del sottosistema di routing:

- Selezione e filtraggio dei pacchetti
- NAT
- Tracciamento delle connessioni
- Accounting di rete.

Per quanto riguarda il filtraggio dei pacchetti, abbiamo a disposizione 5 hook differenti:

- `NF_INET_PRE_ROUTING`: e' chiamato nel metodo `ip_rcv()` del kernel, quinid ancora prima di entrare nel sottosistema di routing.
- `NF_INET_LOCAL_IN`: e' chiamato nel momento in cui il pacchetto e' indirizzato al local host.
- `NF_INET_FORWARD`: e' chiamato dopo che e' stato effettuato il lookup nel sottosistema di routing.
- `NF_INET_POST_ROUTING`: e' chiamato per i pacchetti che devono essere inoltrati, pochi istanti prima che il pacchetto entri fisicamente nel cavo.
- `NF_INET_LOCAL_OUT`: e' chiamato per i pacchetti creati nel local host, prima che escano.

Molte utility, comunemente usate, si basano sul sottosistema netfilter:

- `iptables`: agisce come front-end per netfilter ed implementa un **firewall**. Fornisce un'interfaccia per aggiungere, eliminare, regole netfilter, aggiungere tabelle, ecc...
- `nftables`: e' sviluppato da **netfilter** (l'organizzazione dietro al sottosistema netfilter). E' un rimpiazzo per iptables che e' riconosciuto avere problemi di scalabilita e performance.

iptables utilizza le **tables** per organizzare i filtri da applicare, suddividendo le regole in classi di **table**. In BlueAgent abbiamo utilizzato per esempio la classe `nat`, usata per definire le regole per applicare il NAT.

Spesso le connessioni a livello applicativo hanno una connessione mantenuta nel tempo ed una serie di eventi che determinano la storia della comunicazione. Il **Connection Tracking** (`cpnntrack`) Layer permette al kernel di tenere traccia delle sessioni create, e' la struttura dati fondamentale per implementare il NAT. `conntrack` mantiene per ogni connessione che deve usufruire del NAT le traduzioni necessarie per gli indirizzi IP.

[4] https://linuxhandbook.com/iptables-vs-nftables/

7.2 WireGuard [5]

La **VPN** e' un servizio usato per comunicare in modo sicuro tra membri di un gruppo attraverso l'uso di una infrastruttura di comunicazione pubblica su cui il traffico viene incapsulato dentro ad un tunnel cifrato. [6]

Wireguard e' una VPN che utilizza il concetto di **cryptokey routing**: viene mantenuta in memoria una tabella dove ad ogni chiave pubblica di un peer, viene associata una lista di indirizzi ip identificati come allowed. Fornisce un'interfaccia stateles per utilizzare il tunnel VPN, ossia un'interfaccia di rete virtuale, che potrebbe essere per esempio `wg0`.

> Per **stateless**, si intende il fatto che l'amministratore non si deve occupare di gestire lo scambio delle chiavi, connessioni, disconnessioni, poiche' viene tutto gestito dietro le quinte da WireGuard.

Rispetto ad OpenVPN, Wireguard e' percepito come più sicuro ed efficiente:

- OpenVPN utilizza TLS ed espone molte delle sue funzionalità, aumentando la superficie di attacco sulla VPN.
- OpenVPN utilizza interfacce TUN/TAP: agiscono in user space ma al costo di penalizzare di molto le performance, infatti i pacchetti devono essere copiati piu volte nel passagio da user spa ce a kernel space.

Wireguard non utilizza un meccanismo specifico per scambiare le chiavi, e non include dunque un protocollo interno per la distribuzione delle chiavi, si delega lo scambio a meccanismi esterni e preesistenti (come ad esempio SSH). In pratica lo scambio delle chiavi si fa per esempio manualmente, si copia e incollano le chiavi pubbliche nel file di configurazione di wireguard oppure si usano tool automatizzati.

Una cryptorouting table appare cosi:

Configuration 1a

Interface Public Key	**Interface Private Key**	**Listening UDP Port**
HIgo...8ykw	yAnz...fBmk	41414
Peer Public Key	**Allowed Source IPs**	
xTIB...p8Dg	10.192.122.3/32, 10.192.124.0/24	
TrMv...WXX0	10.192.122.4/32, 192.168.0.0/16	
gN65...z6EA	10.10.10.230/32	

Figura 7.1: Pasted Image 20261001214515

Decide quali coppie (Peer Public Key, Allowed Source IP) possono instradare nell'interfaccia wireguard.

[5] https://www.wireguard.com/papers/wireguard.pdf
[6] https://ieeexplore.ieee.org/document/4756450

Opzionalmente e' possibile specificare verso quale endpoint inoltrare il pacchetto. L'**endpoint** identifica l'indirizzo ip e la porta UDP su cui il demone WireGuard e' in ascolto.

Brevemente il flusso dei dati e' il seguente:

- l'interfaccia `wg0` riceve un pacchetto
- il client incapsula il pacchetto all'interno di una datagramma UPD il cui payload viene crittografato utilizzando `ChaCha20Poly1305`
- il client invia il datagramma all'endpoint specificato, oppure imparato dal Wireguard in precedenza.
- il server riceve il dataramma, verifica la correttezza nella *cryptokey routing table*
- il server autentica e decripta il messaggio ed estrae il pacchetto originario
- il pacchetto originario viene inserito in una coda nell'interfaccia wg0

7.3 ZFS [7]

In ZFS si segue questo principio base: *Un blocco in uso non viene mai sovrascritto.*

Modificare dati vuol dire dunque scrivere il contenuto in una nuova porzione di memoria, ed il filesystem dovra essere modificato per puntare a questa nuova area.

Questo principio, permette di implementare e gestire facilmente feature avanzate come snapshots ed il self-healing dei dati.

In ZFS lo storage e' organizzato all'interno di una pool, ossia una struttura ad albero:

- le foglie contengono i dati
- i nodi interiori sono dei **block pointers**
- l'**uberblock** e' il nodo radice, tutta la pool e' navigabile a partire da qui.

Un block pointer tiene traccia di un insieme di blocchi e ne traccia la grandezza e la **checksum**. Ogni nodo dell'albero calcola la checksum in base al contenuto delle informazioni dei figli. Quindi, modificare dati nel filesystem vuol dire ricalcolare le checksum e ricostruire la catena dei padri a partire dalla foglia, aggiornando le informazioni.

Dopo aver applicato la catena di modifiche a partire dalla foglia, si ottiene un nuovo uberblock', ossia il nuovo albero che descrive il filesystem con i nuovi dati e le checksum aggiornate. L'intera operazione descritta fino ad ora e' **atomica**.

Il costo per una modifica nella pool e' proporzionale alla profondita dell'albero, che non e' necessariamente legato alla grandezza in byte della pool. Questo approccio permette di tenere in memoria sia uberblock' che la vecchia radice uberblock.

[7] https://openzfs.org/wiki/System_Administration

ZFS segue un modello transazionale: le operazioni sono organizzate in gruppi di transazioni chiamti `txg` ed l'intero gruppo viene eseguito atomicamente.

7.3.1 Vantaggi di Pool e transazioni

Gli snapshot del filesystem vengono eseguiti a costo quasi zero: fare uno snapshot vuol dire, chiedere al filesystem di non liberare i dati delle foglie se questi devono essere eliminati o modificati in versioni future dell'albero. Per indirizzare i dati bisogna tenere in memoria l'uberblock e l'intero albero che descrive l'albero al momento dello snapshot.

> Uno snapshot in ZFS e' una copia read-only del sistema o di un volume ad un determinato istante. Creare uno snapshot e' un'operazione quasi istantanea, non consuma spazio ed e' atomica.

ZFS e' in grado di identificare gli erorri: nei blocchi grazie al controllo della corrispettiva checksum che risiede nel padre. Se nella pool esiste una copia, ridondante dei dati, allora ZFS puo' automaticamente ripristinarne il contenuto.

7.3.2 Quando ZFS diventa costoso?

Modificare un file vuol dire allocare qua e la nella pool nuovi blocchi, rompendo la sequenzialità dei blocchi nel file system. Ne consegue che le performance di ZFS in fase di allocazione dipendono da quanto e' grande la pool e da quanto e' frammentata la memoria libera.

> Se la pool e' vuota allora trovare spazio contiguo e' facile. Altrimenti l'allocatore deve lavorare per trovare spazio per nuovi dati.

Inoltre bisogna tenere presente che per fare qualsiasi modifica, anche un'eliminazione, ZFS ha bisogno di memoria per creare i nuovi metadati. In generale per fare una modifica parziale ad un record, bisogna leggerlo, modificarlo e scriverlo dentro ad un nuovo record da attaccare all'albero. Dunque piccole modifiche frequenti possono essere costose.

7.4 NsJail e Container [8]

Si vuole in questo capitolo approfondire i meccansmi utilizzati da NsJail per l'isolamento delle risorse del kernel Linux. Tutti questi meccanismi utilizzati da NsJail sono utilizzati anche da Docker e Incus per implementare i container e verra' visto brevemente in che modo.

[8] https://nsjail.dev/

7.4.1 Namespaces [9]

Un namespace e' una feature del kernel Linux che permette di partizionare le risorse del kernel in modo che:

- un insieme di processi e' in grado di vedere un certo insieme di risorse
- un'altro insieme di processi e' in grado di vedere un'altro insieme di risorse.

Il kernel linux supporta diverso tipi di namespace: Cgroup, IPC, Network, Mount, PID, Time, User ed UTS.

Il **PID namespace** permette di partizionare gli ID dei processi in modo che per esempio, su 2 PID namespace differenti possano coesistere due processi con process ID identici. Inoltre un processo che esegue sul pid namespace `A` non puo' vedere quali processi sono in esecuzione sul pid namespace `B`.

Il **Network namespace** invece offre l'isolazione delle risorse di networking, come device, lo stack IPv4, le tabelle di routing, ecc. Un device fisico vive all'interno di un'unico network namespace, e le connessioni tra namespace sono gestite dai device `veth`.[10]

Banalmente, i container usano i namespace per creare un'ambiente separato in cui istanziare i processi, il filesystem e le interfacce di rete.

7.4.2 Seccomp [11]

Seccomp permette ad un processo di specificare un filtro per le chiamate di sistema. Il filtro e' espresso come un programma `eBPF`, che opera sul numero della syscall ed i suoi argomenti. Fornisce un meccanismo per minimizzare l'esposizione del kernel.

Guardiamo brevemente come si usa `seccomp`, prendendo ad esempio la specifica per il linguaggio `C`:

- Si inizializza nel codice il filtro `scmp_filter_ctx ctx`
- Si aggiungono le regole usando `seccomp_rule_add(ctx, ...)`
- Si caricano le regole con `seccomp_load(ctx, ...)`. In questo modo, il processo che esegue il codice sara soggetto alle limitazioni di `seccomp`.

I container Docker (quindi non privilegiati) usano Seccomp per limitare le chiamate di sistema considerate pericolose, mentre Incus nei container di sistema non applica filtri.

[9] https://man7.org/linux/man-pages/man7/namespaces.7.html
[10] https://man7.org/linux/man-pages/man7/network_namespaces.7.html
[11] https://www.man7.org/linux/man-pages/man2/seccomp.2.html

7.4.3 cgroups [12]

I Control Groups sono un meccanismo per aggregare o partizionare insiemi di task, ed i loro figli in gruppi gerarchici.

In particolare, la documentazione del kernel Linux riporta le seguenti definizioni:

- `cgroup`: un cgroup associa un insieme di task con un insieme di parametri per uno o piu sottosistemi.
- `sottosistema`: un sottosistema e' un "resource controller" che schedula una risorsa, oppure applica limitazioni alla risorsa ad un certo raggruppamento di task

Dunque con un `cgroup` posso schedulare la risorsa CPU all'interno di un gruppo definito di task. Viene utilizzato per effettaure il tracciamento dei job, accountig e limitazione delle risorse.

Nei container i `cgroup` sono utilizzati per impostare un tetto massimo alle risorse utilizzabili e fare accounting delle risorse utilizzate.

[12] https://www.kernel.org/doc/html/latest/admin-guide/cgroup-v1/cgroups.html

Elenco delle figure

2.1 Kctf Architecture 3
2.2 Ctfbox Architecture 6
2.3 Cytrone Architecture 8
2.4 Cytrone Training 10
2.5 Cytrone Cyberrange 11
2.6 Cytrone Performance 13
2.7 Cytrone Largescaleperformance 14
2.8 Kypo Basic Elements Sandboxes 16
2.9 Kypo Topology Instance 19

4.1 Production Network 35
4.2 Verify Network 38

5.1 Graph1 Cow Vs Deploy 45
5.2 Graph2 Microphase Breakdown 45
5.3 Graph3 Memory Scaling 46

7.1 Pasted Image 20261001214515 54

Elenco dei codici

Elenco degli algoritmi

Bibliografia

[1] Google Security Team, “kCTF: Kubernetes-based Infrastructure for Capture The Flag Competitions,” https://google.github.io/kctf/, 2020, accessed: 2026-10-12.

[2] ——, “kCTF Security Threat Model and Sandbox Architecture,” https://github.com/google/kctf/blob/v1/docs/security-threat-model.md, 2021, accessed: 2026-10-12.

[3] G. Antoniak and Google Security Team, “NsJail: A Light Approach to Process Isolation on Linux Using Namespaces and Seccomp-BPF,” https://github.com/google/nsjail/, 2016, accessed: 2026-10-12.

[4] Cloud Native Computing Foundation, “Kubernetes: Production-Grade Container Orchestration,” https://kubernetes.io/, 2024, accessed: 2026-10-12.

[5] Domy, “CTFBox: Open-Source Attack-Defense CTF Platform,” https://ctfbox.domy.sh/, 2023, accessed: 2026-10-12.

[6] C.-K. Pham, R. Beuran, and Y. Shinoda, “CyTrONE: An Integrated Cybersecurity Training Framework,” *Computers & Security*, vol. 78, pp. 218–238, 2018.

[7] Cybersecurity Research and Development Group, JAIST, “CyTrONE: Cybersecurity Training Organizer and Network Environment,” https://github.com/crond-jaist/cytrone, 2018, accessed: 2026-10-12.

[8] Masaryk University, “KYPO Cyber Range Platform and CyberRangeCZ Architecture,” https://docs.platform.cyberrange.cz/, 2022, accessed: 2026-10-12.

[9] Air & Space Forces Association, “CyberPatriot: The National Youth Cyber Education Program,” https://www.uscyberpatriot.org/, 2024, accessed: 2026-10-12.

[10] M. M. Yamin, B. Katt, and M. Nowostawski, “Serious Games and Cyber Ranges: A Survey of Cyber Ranges and Testbeds for Cybersecurity Education, Training, and Testing,” *Sensors*, vol. 20, no. 24, p. 7148, 2020.

[11] M. Parisi *et al.*, "Current Status and Capabilities of SAST Tools in Software Security," *Advances in Emerging Trends with Science and Emerging Technologies (AETIC)*, vol. 4, no. 3, pp. 1–12, 2020.

[12] D. Breuker, "pspy: Monitor Linux Processes Without Root Permissions," https://github.com/DominicBreuker/pspy, 2021, accessed: 2026-10-12.

[13] CTFd LLC, "CTFd: The Open-Source Capture The Flag Platform," https://ctfd.io/, 2024, accessed: 2026-10-12.

[14] Linux Containers Project, "Incus: Powerful System Container and Virtual Machine Manager," https://linuxcontainers.org/incus/docs/main/, 2024, accessed: 2026-10-12.

[15] ——, "Incus Documentation: OVN Network Driver and Overlay Topology," https://linuxcontainers.org/incus/docs/main/reference/network_ovn/, 2024, accessed: 2026-10-12.

[16] J. A. Donenfeld, "WireGuard: Next Generation Kernel Network Tunnel," in *Proceedings of the Network and Distributed System Security Symposium (NDSS)*, 2017.

[17] J. Gross, I. Ganga, T. Sridhar *et al.*, "Geneve: Generic Network Virtualization Encapsulation," IETF, RFC 8926, 2020.

[18] B. Pfaff, J. Pettit, T. Koponen, E. Jackson, A. Zhou, J. Rajahalme, J. Gross, A. Wang, J. Stringer, P. Shelar, K. Amidon, and M. Casado, "The Design and Implementation of Open vSwitch," in *Proceedings of the 12th USENIX Symposium on Networked Systems Design and Implementation (NSDI)*, 2015, pp. 117–130.

[19] Netfilter Project, "nftables Documentation: Forwarding Traffic and TCP MSS Clamping," https://wiki.nftables.org/wiki-nftables/index.php/Forwarding_traffic, 2023, accessed: 2026-10-12.

[20] ——, "nftables Documentation: Performing Network Address Translation (NAT)," https://wiki.nftables.org/wiki-nftables/index.php/Performing_Network_Address_Translation_(NAT), 2023, accessed: 2026-10-12.

[21] G. of Geeks, "Virtual Ethernet Devices (veth) and Network Namespaces in Linux," https://dev.to/godofgeeks/virtual-ethernet-devices-veth-ofd, 2022, accessed: 2026-10-12.

[22] M. Kerrisk, "unix(7) — Linux Programmer's Manual: Sockets for Local Interprocess Communication," https://man7.org/linux/man-pages/man7/unix.7.html, 2021, linux man-pages 5.10.

[23] R. Rosen, *Linux Kernel Networking: Implementation and Theory*. Apress, 2014.

[24] C. Benvenuti, *Understanding Linux Network Internals*. O'Reilly Media, 2006.

[25] OpenZFS Project, "OpenZFS Documentation: Architecture, Datasets, Snapshots and Copy-on-Write," https://openzfs.github.io/openzfs-docs/, 2024, accessed: 2026-10-12.

[26] J. Ellingwood, "A Deep Dive into Iptables and Netfilter Architecture," https://www.digitalocean.com/community/tutorials/a-deep-dive-into-iptables-and-netfilter-architecture, 2015, digitalOcean Community Tutorial.

[27] S. Ramírez, "FastAPI: Modern, High-Performance Web Framework for Python," https://fastapi.tiangolo.com/, 2024, accessed: 2026-10-12.

[28] Encode, "Uvicorn: The Lightning-Fast ASGI Server," https://www.uvicorn.org/, 2024, accessed: 2026-10-12.

[29] Linux Containers Project, "Distrobuilder: System Container Image Building Tool," https://linuxcontainers.org/distrobuilder/, 2024, accessed: 2026-10-12.

[30] B. Stroustrup, *The C++ Programming Language*, 4th ed. Addison-Wesley, 2013, resource Acquisition Is Initialization (RAII).

[31] B. Gleeson, A. Lin, J. Heinanen, G. Armitage, and A. Malis, "A Framework for IP Based Virtual Private Networks," *IEEE Communications Magazine*, vol. 38, no. 2, pp. 58–66, 2000.

[32] M. Kerrisk, "memfd_create(2) — Linux Programmer's Manual: Create an anonymous file in RAM," https://man7.org/linux/man-pages/man2/memfd_create.2.html, 2021, linux man-pages.

[33] ——, "fexecve(3) — Linux Programmer's Manual: Execute program specified via file descriptor," https://man7.org/linux/man-pages/man3/fexecve.3.html, 2021, linux man-pages.

Ringraziamenti

La tua direzione la dà il capo quando sbava
L'arte insegue il mercato, ma non vede la strada
Io cerco le regole e dei modi per infrangerle
Sentirmi così intensamente solo mi fa piange'
Ho dei pensieri strani: a lei farei del male fisico
Per farle sentire cosa ho dentro e quanto tanto mi spaventa
Oh, adesso ti impressioni? Il mio dolore è un eufemismo
Non lo sai quello che sento, però lo vorrei tantissimo

Nayt - guerra dentro

Ringrazio Gemini 4, Gemini 3.1 Pro, Gemini 3.8 Flash ed Antigraivity.